09 de Septiembre del 2026





CONEXIÓN SEGURA ESTABLECIDA

SISTEMAS DE CONTROL DE CIBERSEGURIDAD

DIPLOMATURA UNIVERSITARIA EN SISTEMAS DE CONTROL DE CIBER SEGURIDAD EN REDES

UNPAZ
Universidad Nacional de José C. Paz

SOC_ACADEMY // DIPLOMATURA_CIBERSEGURIDAD

10 MEJORES prácticas de ciberseguridad

01 ACTUALIZA TU SOFTWARE

Esto incluye tus aplicaciones, navegadores web y sistemas operativos.

02 ASEGURA TUS DATOS

Respalda offline tus archivos importantes, en un disco duro externo o en una nube.

03 EXIGE CLAVES

Usa claves en todas las computadoras portátiles, tabletas y teléfonos inteligentes.

04 ENCRIPTA CLAVES

Encripta dispositivos y otros medios que contengan información personal sensible.

05 USA AUTENTIFICACIÓN MULTIFACTOR

Requiere autenticación multifactor para acceder a áreas de tu red de trabajo que contenga información sensible.



ASEGURA TU ROUTER 06

Cambia el nombre y contraseña, desactiva la gestión remota y cierra la sesión como administrador una vez configurado.

USA POR MENOS WPA2 CIFRADO 07

Asegurate de que tu router ofrezca WPA2 o WPA3 cifrado y que esté encendido.

REQUIERE CONTRASEÑAS SEGURAS 08

De al menos 12 caracteres que sean una mezcla de número, símbolos y letras mayúsculas y minúsculas.

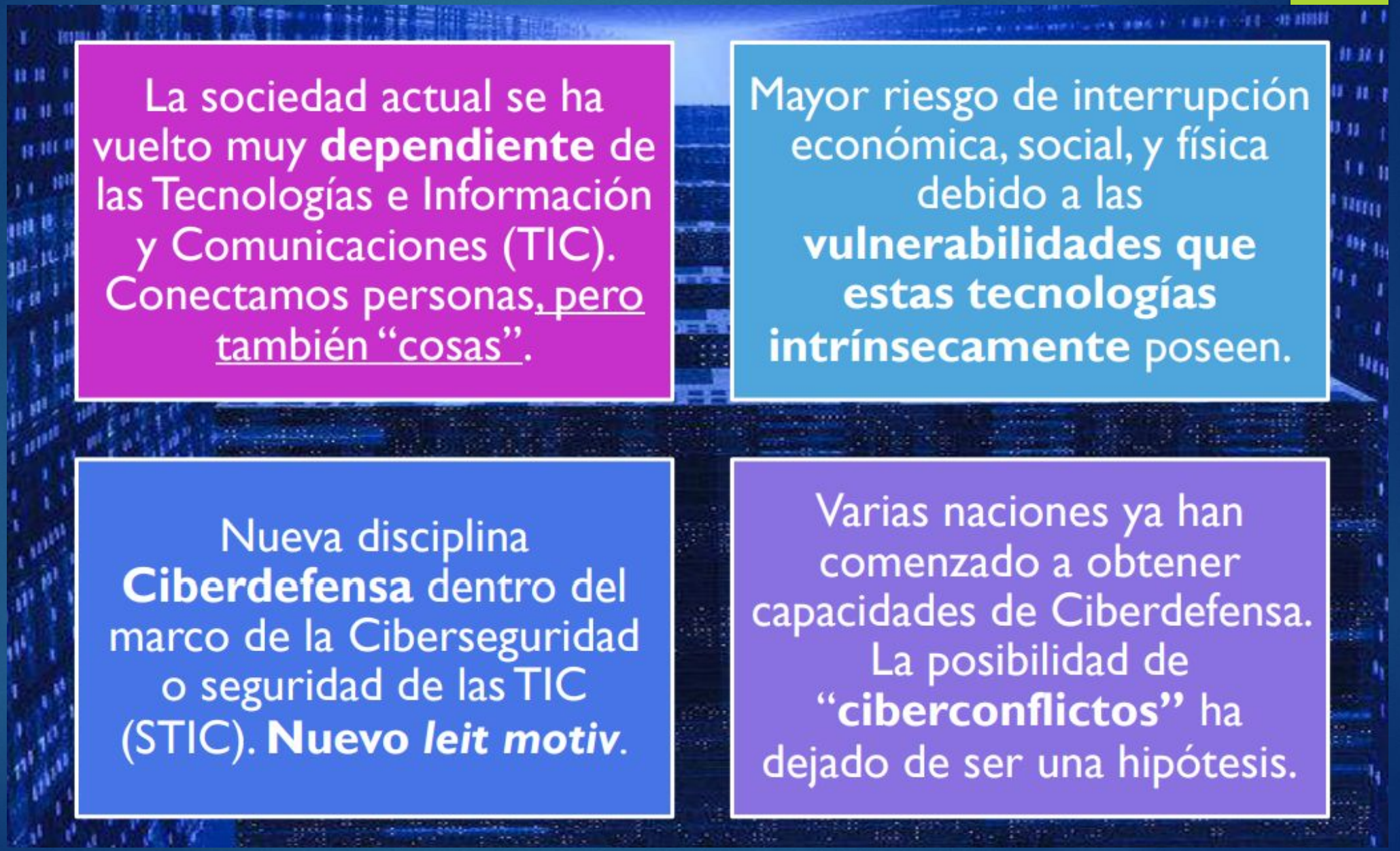
ENTRENA A TODO TU EQUIPO 09

Crea una cultura de seguridad. Actualiza a tus empleados a medida que te enteres de nuevos riesgos y vulnerabilidades.

TEN UN PLAN 10

Ten un plan para salvar datos, manejar el negocio y notificar a clientes en caso de experienciar una brecha.

SECURITYSIGNAL


La sociedad actual se ha vuelto muy **dependiente** de las Tecnologías e Información y Comunicaciones (TIC). Conectamos personas, pero también "cosas".
Mayor riesgo de interrupción económica, social, y física debido a las **vulnerabilidades que estas tecnologías intrínsecamente** poseen.
Nueva disciplina **Ciberdefensa** dentro del marco de la Ciberseguridad o seguridad de las TIC (STIC). **Nuevo *leit motiv***.
Varias naciones ya han comenzado a obtener capacidades de Ciberdefensa. La posibilidad de "**ciberconflictos**" ha dejado de ser una hipótesis.

Video de introducción



CIBERESPACIO

Definición:

Conjunto de medios físicos y lógicos que conforman las infraestructuras de los sistemas de comunicaciones e informáticos, junto con los usuarios que interactúan con estos sistemas.

Composición:

capas **física**, **lógica** y **social**

Características:

Anonimato.

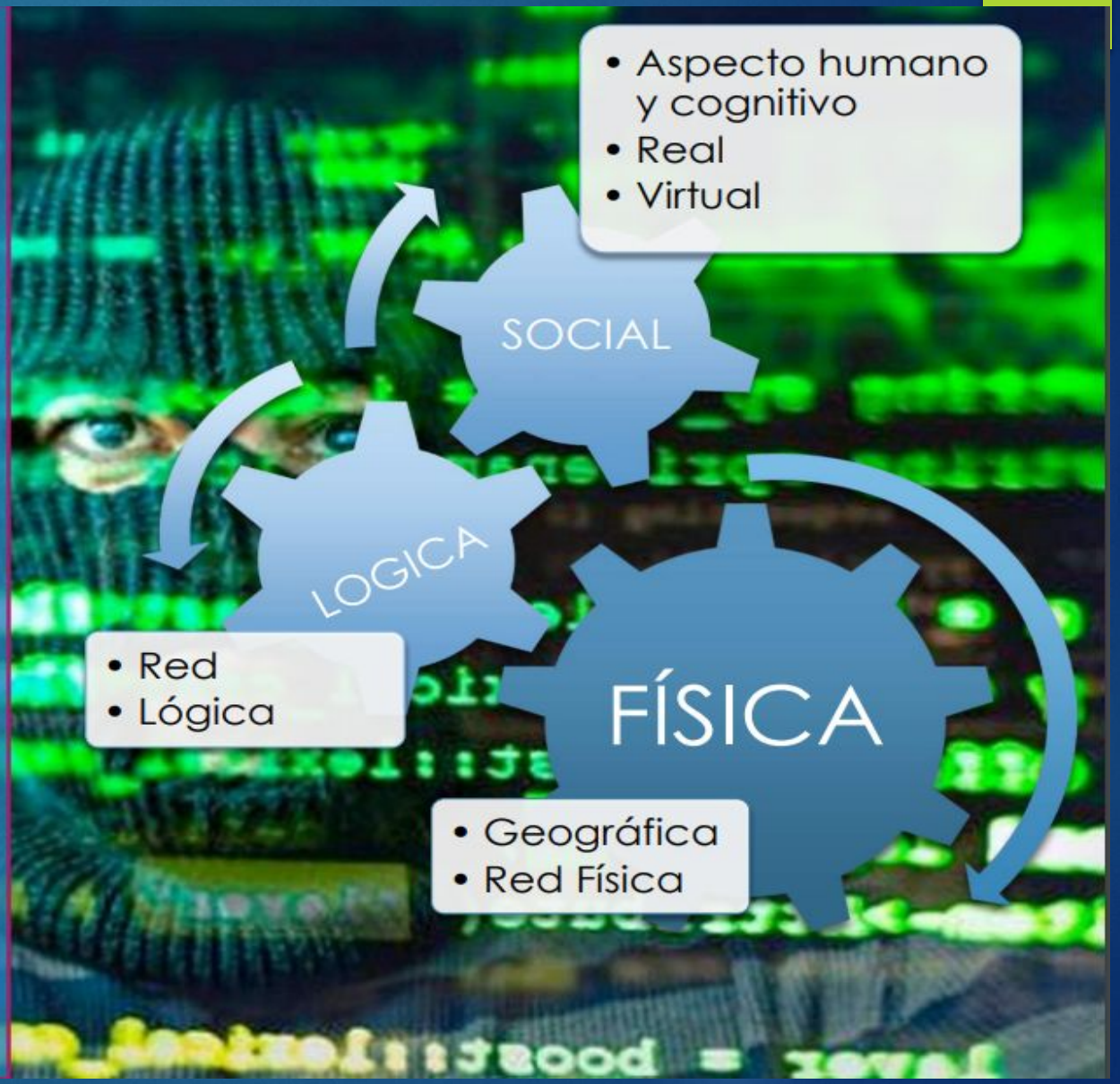
No tiene fronteras definidas.

Falta de regulación.

Escaso coste de las acciones en relación con otros dominios.

Alcance para todas las personas de manera sencilla.

Construido a base de tecnologías inseguras en su diseño.



Nociones

- Típicamente incluye un “sistema de información” y dispositivos.
- Seguridad de la información se relaciona con un “objetivo de la seguridad” o “política de seguridad”: qué cosa será prevenida? Qué actividad o eventos deberán ser detectados?
- La política de seguridad usualmente se define en términos de:
  - Actores o participantes, quizás en términos de roles.
  - Definir acciones u operaciones permisibles (o inadmisibles).
  - Objetos o clases de objetos

Conceptos de seguridad informática

¿Qué se debe asegurar?

– Los activos de una organización

¿Cuál es el lugar que ocupa la información?

–La información constituye un activo muy importante para la organización, ya que tiene un rol fundamental a la hora de cumplir sus objetivos

Debemos proteger la información adecuadamente garantizando su seguridad y privacidad

Conceptos de seguridad informática

¿Qué significa garantizar la seguridad de la información?

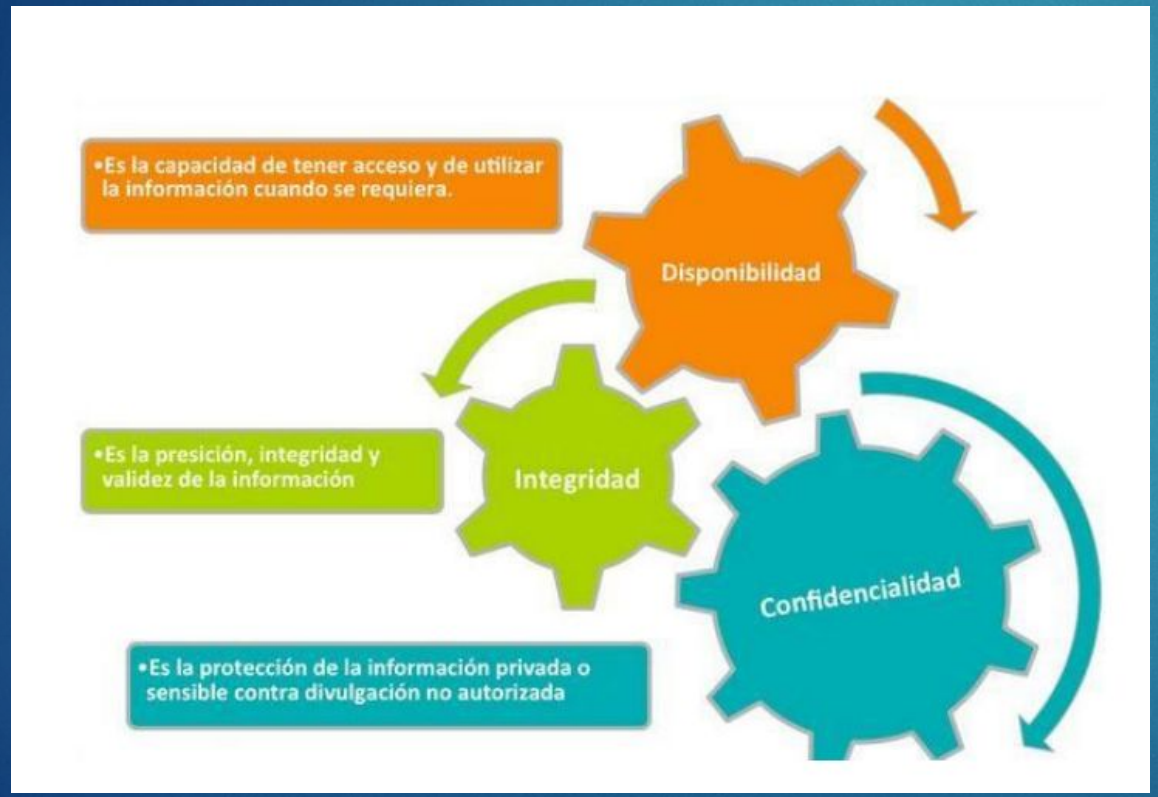
–Significa proteger la información y los sistemas de información del acceso, uso, divulgación, interrupción, modificación o destrucción **no autorizados.**

¿Qué es garantizar la privacidad de la información?

–Significa **no revelar** la información o revelarla selectivamente de manera de protegerla de cualquier intromisión.



Seguridad de la información, Seguridad informática y Ciberseguridad.





Seguridad informática

Medidas y controles para asegurar la **confidencialidad**, **integridad** y **disponibilidad** de los recursos de un sistema de información, incluyendo hardware, software, firmware, y la información que está procesando, está almacenada o está siendo transmitida.

Disponibilidad: Hace referencia a que la información esté accesible cuando la necesitemos. (En todo momento) – Por ejemplo Paginas Web, Copias de Seguridad, Raid de disco, etc.

Integridad: Garantiza que la información solo pueda ser modificada por quien este autorizado a hacerlo. (Que el dato sea verdadero) – Por ejemplo, cambiar la nota de una materia de la Universidad.

Confidencialidad: Propiedad por la que la información no se pone a disposición o no se revela a individuos, entidades o procesos no autorizados. (Acceso autorizado y denegar acceso no autorizado), Por ejemplo – Ver la nota de un compañero/a de mi clase.

¿Qué significa garantizar la seguridad de la información?

Significa proteger la información y los sistemas de información del acceso, uso, divulgación, interrupción, modificación o destrucción ***NO AUTORIZADOS.***

Seguridad de la información:

Básicamente busca proteger la información de todos los posibles riesgos que se puedan alterar, ya sean, físicos o lógicos en cualquier medio informático.

Seguridad Informática: Que está básicamente busca la ***PROTECCIÓN*** de la Infraestructura y los equipos informáticos que la contienen de manera física y lógica.
Acabamos con esto de física y lógica, ya que tenemos que entender que en la informática tenemos tanto software como hardware.

Ciberseguridad: Todos los ***PROCESOS Y MEDIDAS*** de seguridad que se aplican principalmente para proteger la información a nivel lógico aquí no entramos nada en **físico.**

CiberDefensa: Ir más allá y poner en riesgo la integridad de un país y de sus ciudadanos. Entonces, el enemigo virtual solo se puede combatir con Ciberdefensa. El organismo principal de esta defensa, es la Subsecretaria de CiberDefensa de la Nación.

Seguridad Informática: Que está básicamente busca la ***PROTECCIÓN*** de la Infraestructura y los equipos informáticos que la contienen de manera física y lógica.

Acabamos con esto de física y lógica, ya que tenemos que entender que en la informática tenemos tanto software como hardware.

Las 03 (Tres) definiciones se asocian entre sí y son compatibles, buscando proteger la Integridad, la confidencialidad y disponibilidad.

“La seguridad de la información es como un libro y que la seguridad informática y la ciberseguridad son capítulos dentro de ese libro”

Conceptos de seguridad informática

Busca que la totalidad de la información esté protegida, para garantizar que esté exenta de modificaciones de usuarios no autorizados.



Garantizar que la información se encuentre a disposición de quienes deben acceder a ella.

Prevenir la divulgación de información a personas no autorizados.

Conceptos de seguridad informática

Confidencialidad
Integridad
Disponibilidad
Autenticidad
Responsabilidad

Conceptos adicionales

Autenticidad

Poder asegurarse que un elemento tiene la propiedad de ser genuino, esto es, que sea capaz de verificarse y en el que se pueda confiar; se que tenga confianza en la transmisión de información, en un mensaje o en el remitente de un mensaje.



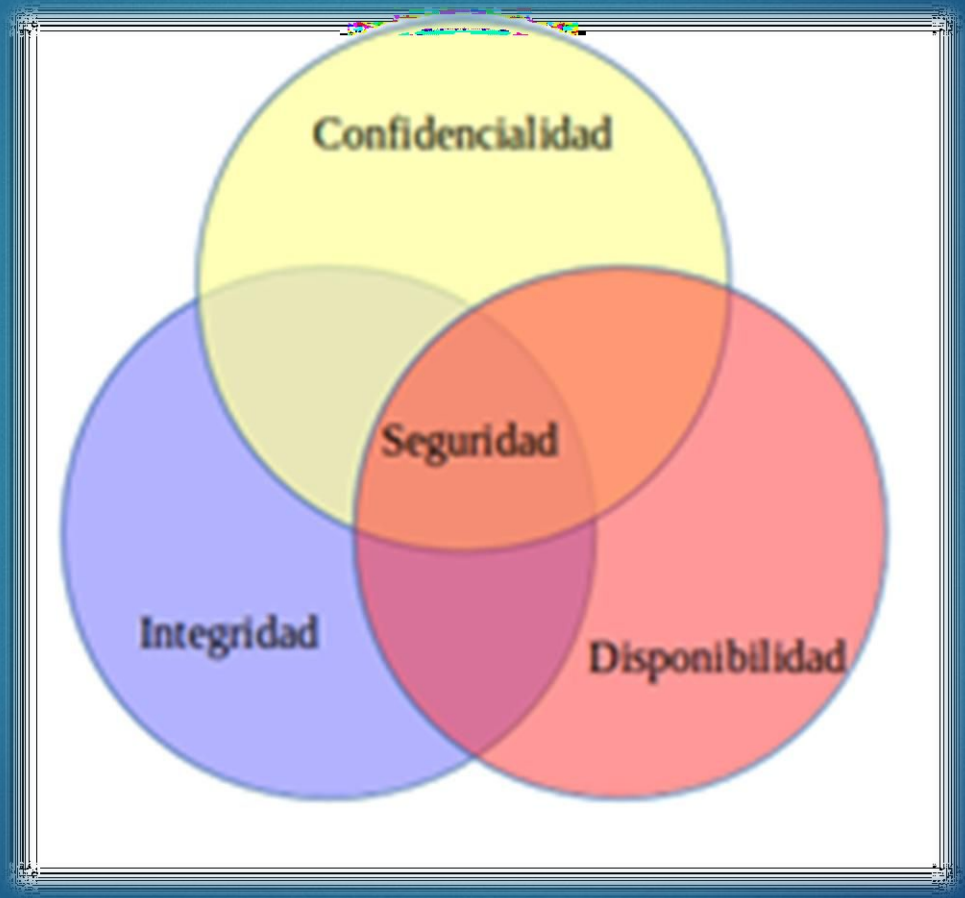
Responsabilidad (Accountability)

Poder asegurar que las acciones de una entidad puedan ser trazadas unívocamente a esa entidad. Esto apoya el no repudio, la disuasión (convencimiento), el aislamiento de fallas, la detección y prevención de intrusos, la recuperación por reconstrucción, y las acciones legales.

Conceptos de seguridad informática

¿Qué se debe garantizar? Atributos

- ✔ Confidencialidad: Garantiza que la información sólo sea accesible por las personas autorizadas.
- ✔ Integridad: Garantiza que la información sólo pueda ser modificada por quien está autorizado a hacerlo
- ✔ Disponibilidad: Garantiza que los usuarios autorizados tienen acceso a la información y recursos relacionados cuando lo necesiten



- Autenticidad: Garantiza que la persona que origina o recibe el mensaje es quien dice ser.
- No repudio: Garantiza que la persona que envió o recibió el mensaje no pueda negar haberlo hecho
- Trazabilidad: Garantiza que toda acción puede ser reproducida

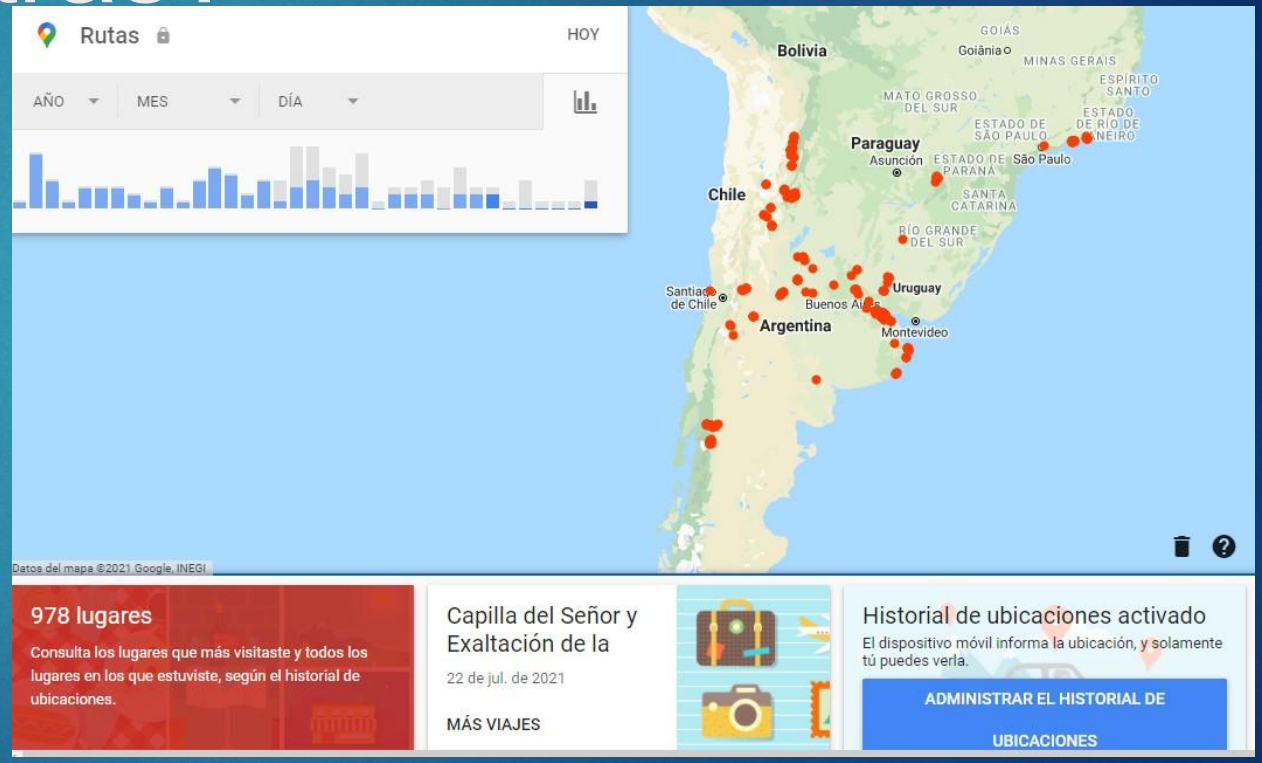
¿Recuerdan dónde estaban exactamente a hace un mes o año atrás?

¿Recuerdan donde estaban exactamente a hace un mes o año atrás?

Verifícalo en:

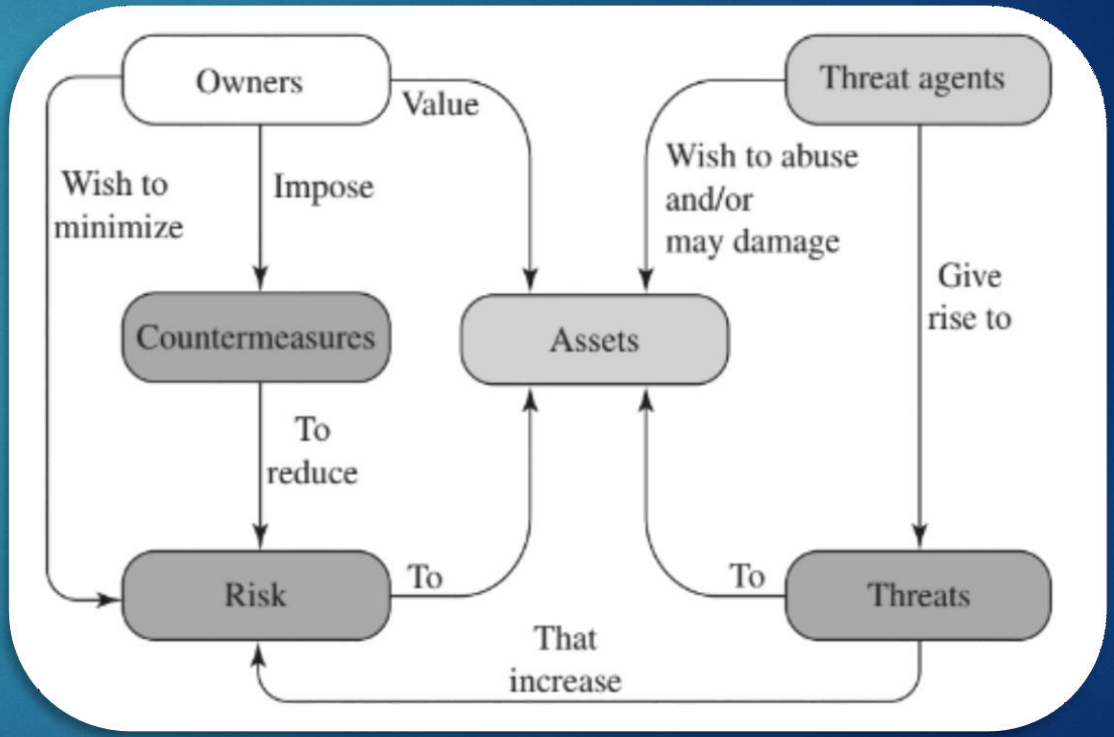
https://maps.google.com/locationhistory

(con sesión iniciada en tu cuenta de Google



Modelo para la **seguridad informática**

- Recursos del sistema (assets): hardware, software, datos, edificios (factor físico), y redes.
- Vulnerabilidades
- Amenazas
- Ataques
- Contramedidas
- Riesgos
- Modelo de amenazas



Vulnerabilidades y Amenazas

Una ***vulnerabilidad*** es una debilidad en un activo

Una ***amenaza*** es una violación potencial de la seguridad.

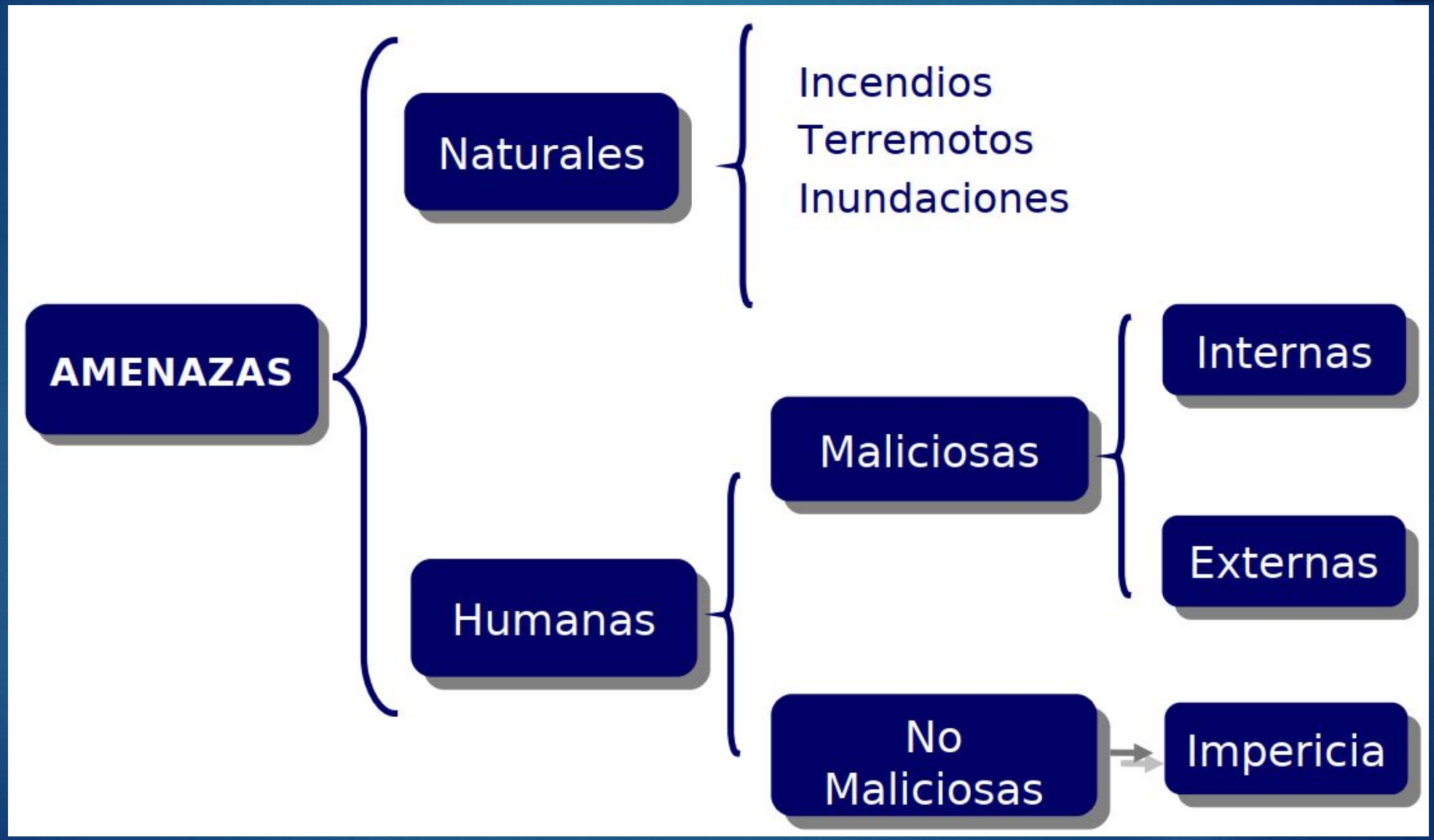
Las amenazas **atentan contra**:



Las amenazas sacan ventaja de las vulnerabilidades.

Tipos de Amenazas

Las Amenazas **son causadas por**



Incidente de Seguridad

La materialización de una **amenaza** se convierte en un **Incidente** de seguridad.

Afecta los activos de la organización. puede causar:

- el acceso, robo, modificación o eliminación de información no autorizada
- la interrupción de un servicio o el procesamiento de un sistema;
- daños físicos o robo del equipamiento y medios de almacenamiento de información

Todo incidente detectado debe ser reportado ante quien corresponda

Ejemplo conceptos

Vulnerabilidad: Ventana sin rejas.

Amenaza: Que alguien pueda entrar a través de esa ventana.

Incidente: Concreción de una amenaza, “un ladrón entró el martes a las 17hs por la ventana y se llevó el televisor”

“Las amenazas sacan ventaja de las vulnerabilidades”

Amenazas Informáticas



Impacto

Son las pérdidas resultantes de la actividad de una amenaza.

- Pérdida de vidas humanas.
- Pérdida de bienes materiales/dinero.
- Violación de las leyes.
- Pérdida de reputación/confianza.
- Reducción en eficiencia/rendimiento operacional.
- Interrupción de la actividad de negocio.



Algunas de las amenazas a las que nos enfrentamos a diario son:



- Ingeniería social
- Phishing
- Defacement
- Denegación de servicios
- Botnet
- Malware
- Ransomware
- Defacement
- Acceso no autorizado.
- Robo de contraseñas.
- Ataque de DDOS
- Robo de información.
- Abuso y/o mal uso de los servicios informáticos internos o externos de una organización.
- Introducción de código malicioso en la infraestructura tecnológica de una organización.

Conceptos de seguridad informática

Estar corrupto, sujeto a filtraciones, o no-disponible, sistemas no actualizados, etc son **Vulnerabilidades del sistema**

Para cada uno de los varios tipos de vulnerabilidades hay **Amenazas** que son capaces de explotar esas vulnerabilidades. Una amenaza representa un **daño potencial** a la seguridad de un recurso del sistema.

Una situación o persona que representa una posible amenaza es un **Riesgo**

Un **Ataque** es una amenaza que es llevada a cabo y, si es exitosa, lleva a una violación no deseada de la seguridad y genera un **Incidente.** Nos referimos al agente que lleva a cabo el ataque como **atacante (threat agent).**

Contramedida / Medidas de protección

Cualquier medio que se toma para enfrentar un ataque de seguridad.

Amenazas en la Organización

Una forma de clasificar

- Amenazas teniendo acceso a las personas de la organización.
- Amenazas teniendo acceso físico a recursos de la organización (hosts, servidores, routers...o a las instalaciones).
- Amenazas teniendo acceso a distintos segmentos de la red de la organización.
- Amenazas teniendo acceso a la organización a través de Internet

Amenazas teniendo acceso a las personas – Ejemplos

- Ingeniería Social
  - Phishing
  -SPAM

Malware entregable

- Ramsomware
- Keylogger
- Botnets
- Acceso no autorizado

La ingeniería social es un conjunto de trucos, engaños o artimañas que permiten confundir a una persona para que entregue información confidencial



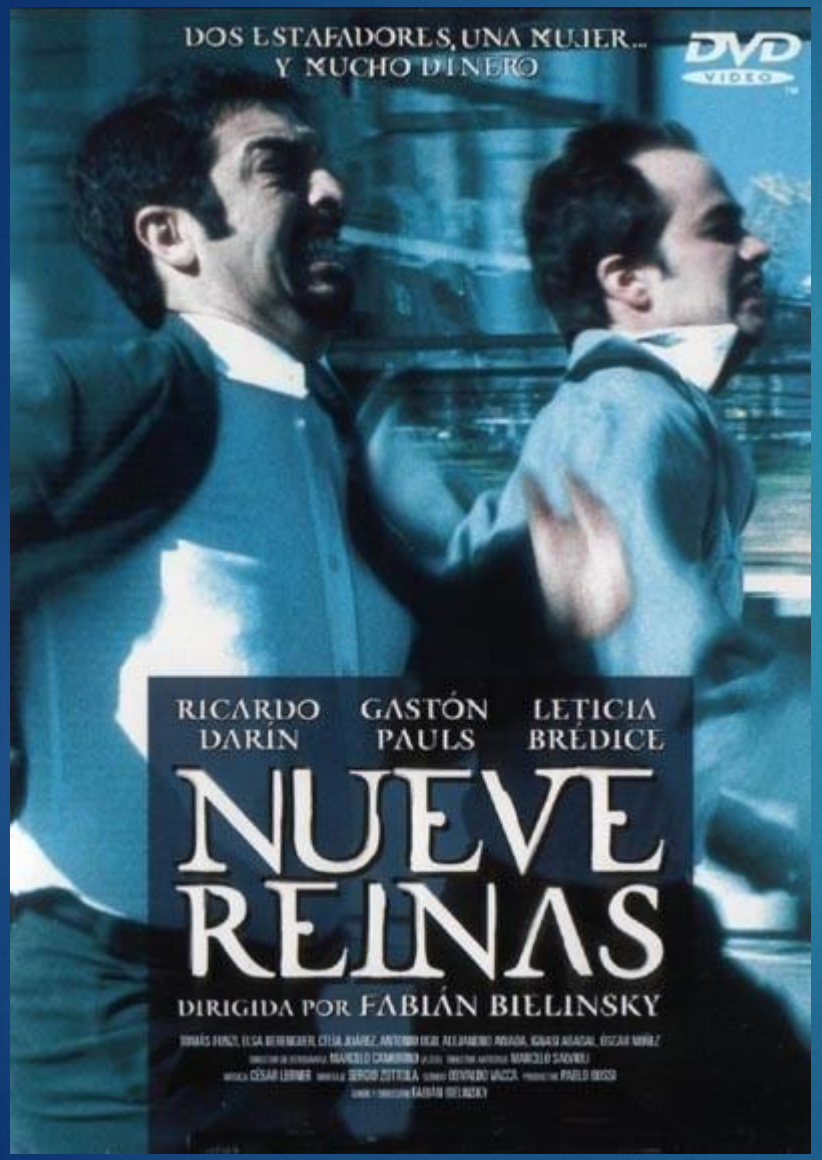
La principal defensa contra es concientizarnos en el uso de políticas de seguridad

Ingeniería Social

- Según Kevin Mitnick, uno de los ingenieros sociales más famosos de los últimos tiempos, la ingeniería social se basa en estos cuatro principios.



Ingeniería Social



"La Seguridad muchas veces es una mera Ilusión. Una compañía puede tener la mejor tecnología, firewalls, sistemas de detección de intrusos, dispositivos de autenticación avanzados como tarjetas biométricas, etc y creen que están asegurados 100%. Viven una Ilusión. Sólo se necesita un llamado telefónico y listo. Ya son vulnerables a un ataque. ***La Seguridad no es un producto, es un Proceso****"*

Kevin Mitnik

Ingeniería Social

Video de Mr. Robot:
https://www.youtube.com/watch?v=OgvxjUgajfo&t=1s

Video de Nueves Reinas:
https://www.youtube.com/watch?v=wUcCW708jz8&list=PL57bh7NU64HQ2FYjei_8rdP305xoDunGj&index=2

Video de practica:
https://www.youtube.com/watch?v=GsOr5ZIMffM

Pishing

El Phishing es una combinación de ingeniería social y elementos técnicos para engañar a un usuario y lograr que éste entregue involuntariamente información confidencial o acceso a sus activos, a usuarios malintencionados.

La forma más común es mediante el envío de mails falsos, escritos como si hubieran sido enviados por la auténtica organización

SPAM (Correo Basura) / SMS o WhatsApp
Los problemas pueden ser: Publicidad no deseada Phishing Transmisión de código malicioso

Ataques homográficos




Alerta de notificacion
Recibidos
Dtoc...@tierra .com.ar
9:16 (hace 8 horas)
para mí
de: NETFLIX <Dtocompras@tierra .com.ar>
para:
fecha: 12 ago. 2020 9:16
asunto: Alerta de notificacion
seguridad: Cifrado estándar (TLS) Más información
Su cuenta de Netflix está Suspendida.
Estimado cliente,
Tu cuenta de Netflix actualmente tiene una o más facturas atrasadas.
Actualice sus detalles de pago en las próximas 48 horas haciendo clic en el botón de arriba para evitar la suspensión y / o limitación de sus servicios de Netflix.
ACTUALICE SUS DETALLES DE PAGO
El equipo de netflix
welivesecurity

Phishing Contramedida

Entre las principales técnicas utilizadas en ataques de phishing, podemos citar:

- Mails basados en HTML, utilizando ofuscación de información de la URL
- Uso de acortadores de URL
- Mensajes falsos utilizando encabezados de los mensajes modificados (From)

Se combina con técnicas de SPAM
Correo, SMS o WhatsApp

Los problemas pueden ser:
- Publicidad no deseada
- Phishing
- Transmisión de código malicioso



Engaños frecuentes. Phishing

Se usa un saludo genérico e impersonal, tal como:
- *“Estimado usuario” o “Estimado [su correo electrónico]”.*

- Transmiten un falso sentido de urgencia para forzar la atención del usuario.

- Cancelaciones de servicio y/o supuesto reembolso.

- Usan excusas tentadoras:
- "Su cuenta está a punto de ser suspendida".
- "Ha recibido un pago".
- "Te han pagado en exceso".
- "Te has ganado un premio".
- "Tus vacaciones todo GRATIS".



¿Cómo reconocer un phishing?

Los ciberdelincuentes actualizan sus tácticas, pero la mayor parte tienen diversos indicios que ayudan a reconocer un mail o texto tipo phishing:

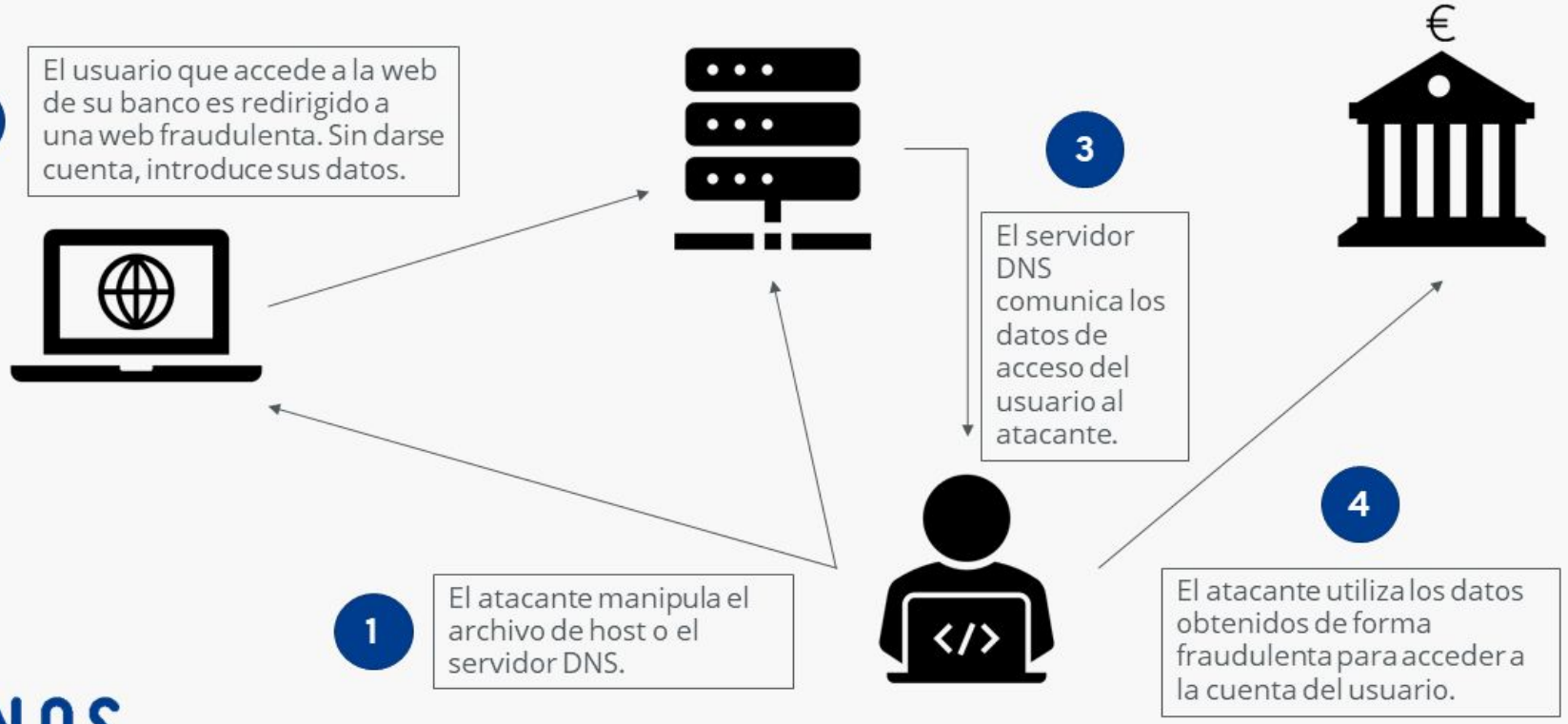
- Decir que se ha detectado alguna actividad sospechosa o intentos de inicio de sesión.
- Afirmar que hay un problema con su cuenta o con su información de pago.
- Decir que debe confirmar algunos datos personales.
- Facturas falsas.
- Pedirle que haga clic en un enlace para hacer un pago.

¿Cómo reconocerlo?

- La dirección del remitente
- Nombre de domino mal escritos
- Errores de ortografía y de gramática
- Archivos adjuntos o enlaces sospechosos
- Sensación de urgencia
- El mensaje es demasiado bueno para ser verdad

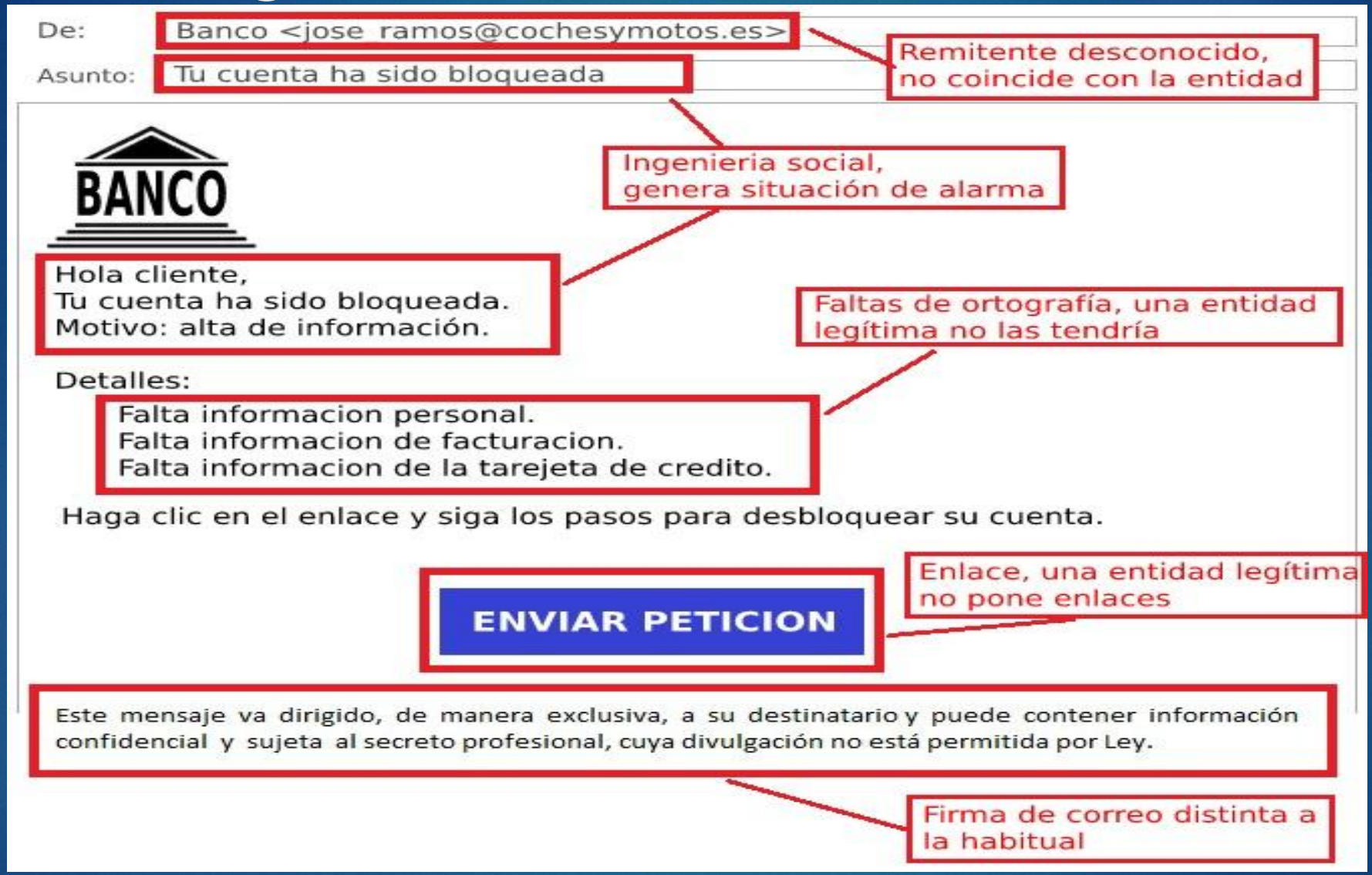


Desarrollo de un ataque de pharming



IONOS

¿Cómo detectar correos

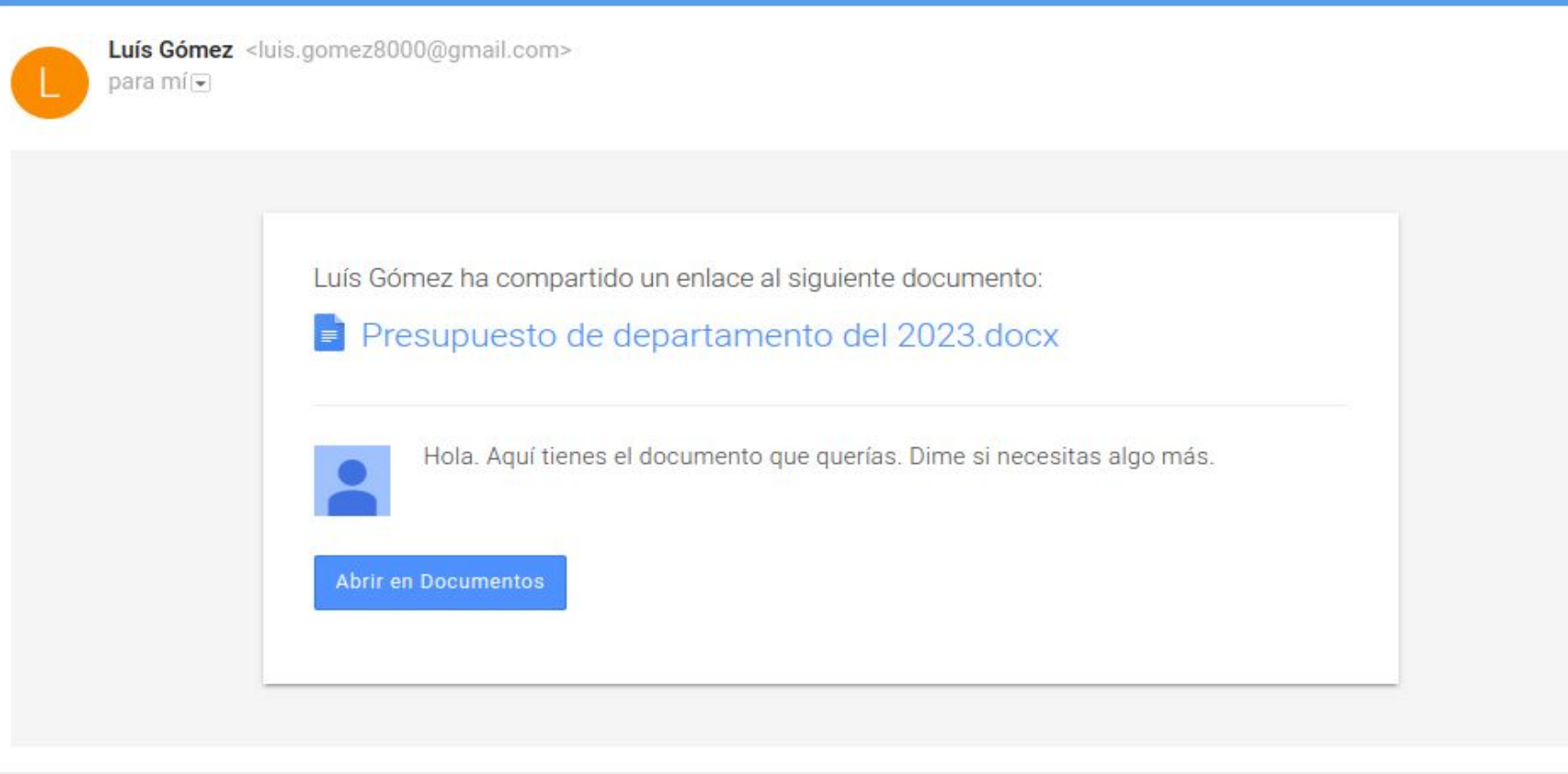


¿Puedes detectar si eres víctima de suplantación de identidad (phishing)?
https://phishingquiz.withgoogle.com/

Empecemos con este correo electrónico que incluye un documento de Google.

Asegúrate de comprobar las URL de los enlaces situando el cursor sobre ellas o manteniéndolas pulsadas de manera prolongada, así como de analizar las direcciones de correo electrónico. No te preocupes; ninguno de los enlaces funciona. ¡No queremos enviarte a sitios peligrosos!

PHISHING | LEGÍTIMO

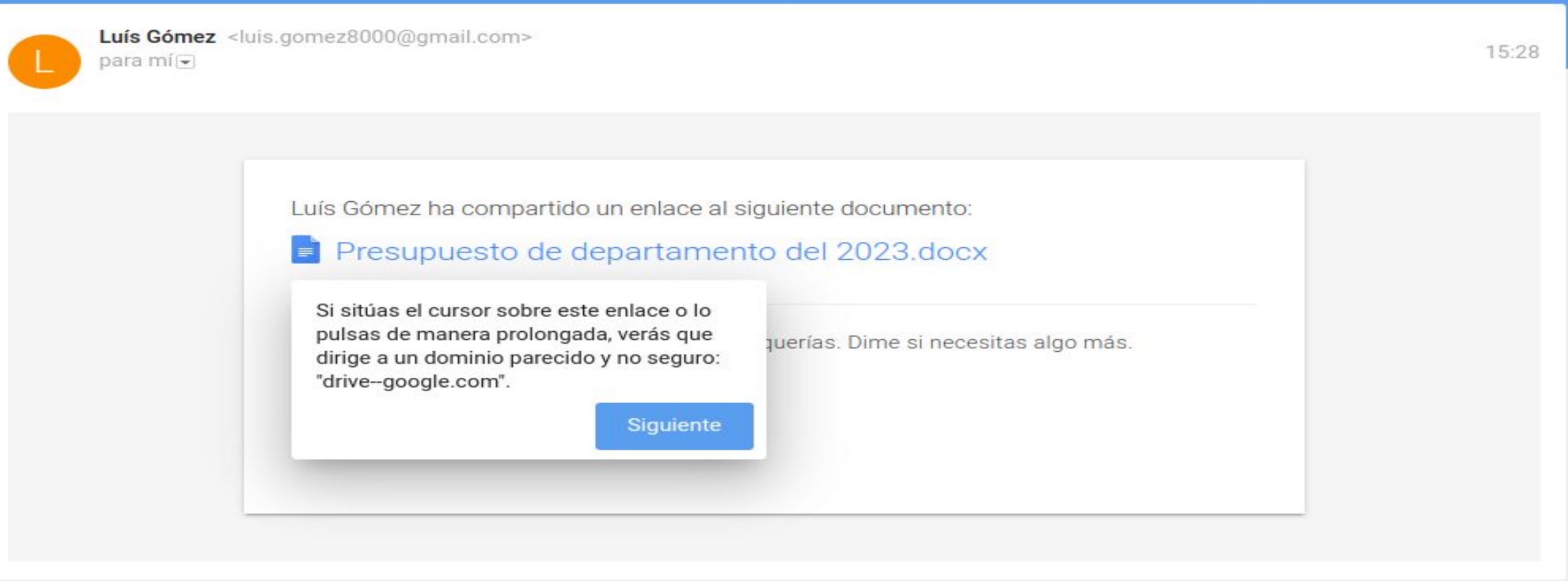


http://drive--google.com/luke.johnson

Correcto. Este es un correo de suplantación de identidad (phishing).

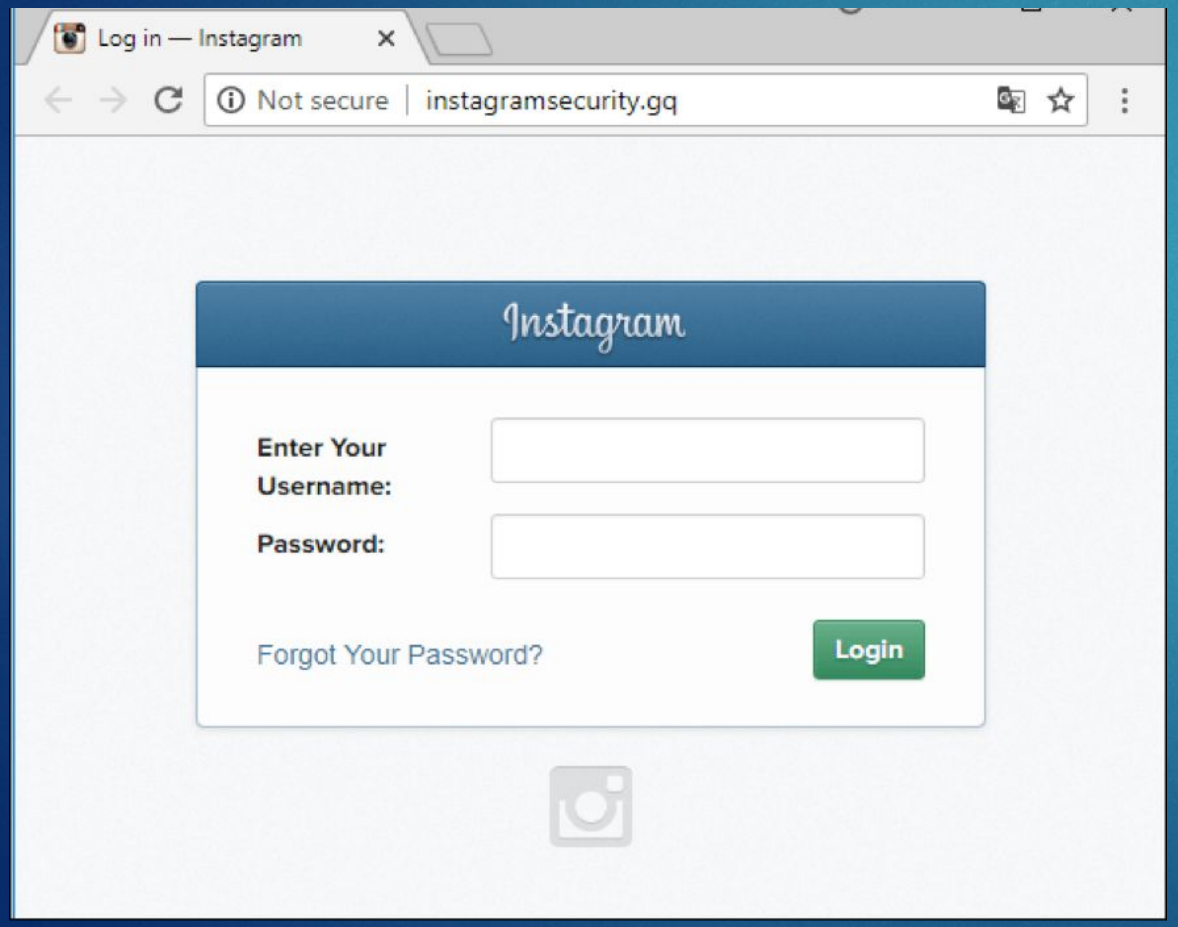
Parece que has detectado la URL engañosa. Ten cuidado con los hiperenlaces y los archivos adjuntos que abras en los correos electrónicos: es posible que te dirijan a sitios web fraudulentos en los que se te solicite información confidencial.

MÁS INFORMACIÓN



Sitios Web maliciosos

Verifica la URL: Examina cuidadosamente la dirección web (URL) de la página. Asegúrate de que sea legítima y esté escrita correctamente.

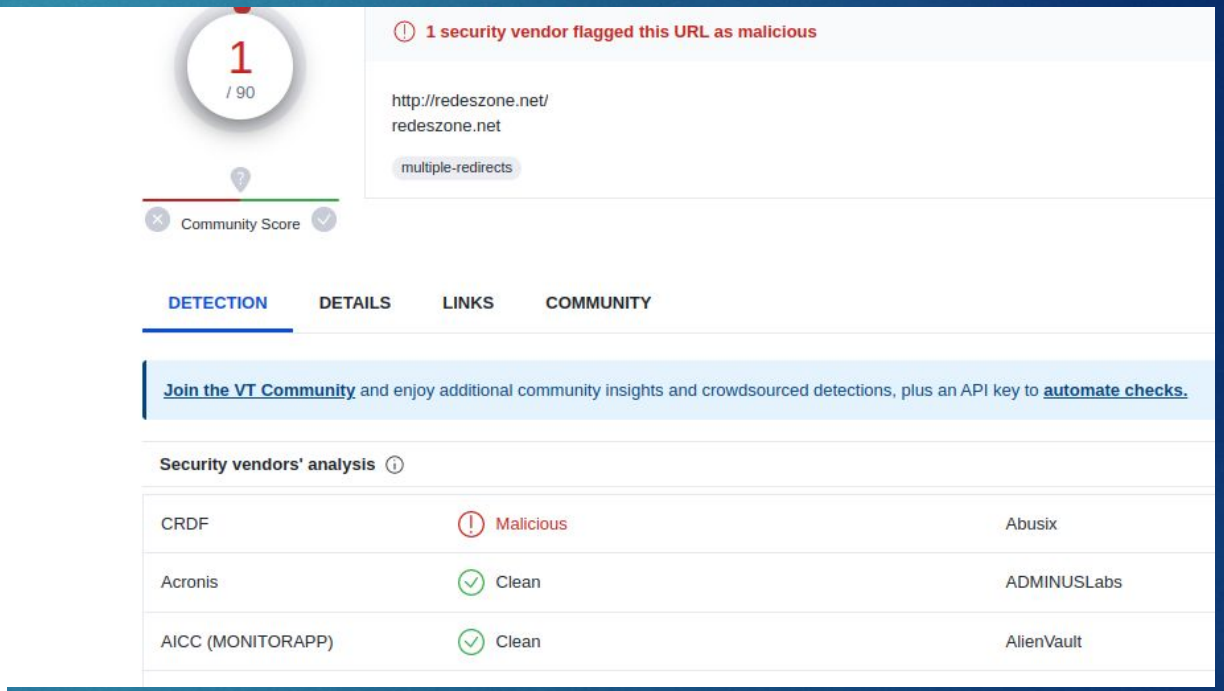




Ejemplos. Sitio Web maliciosos

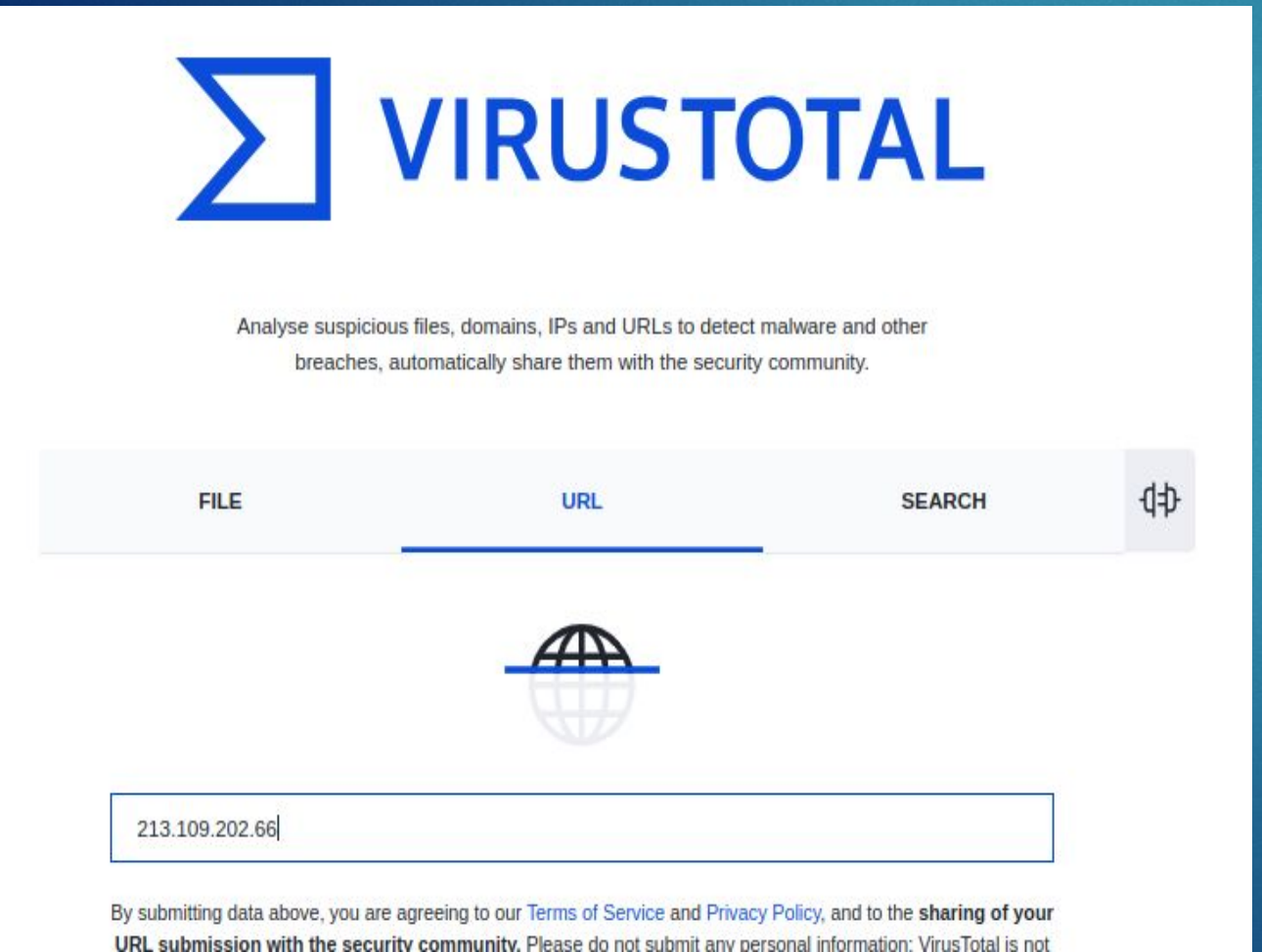
Investiga la reputación del sitio: Utiliza herramientas de seguridad en línea que proporcionen información sobre la reputación y la seguridad de una página web, como por ejemplo, virustotal.com.

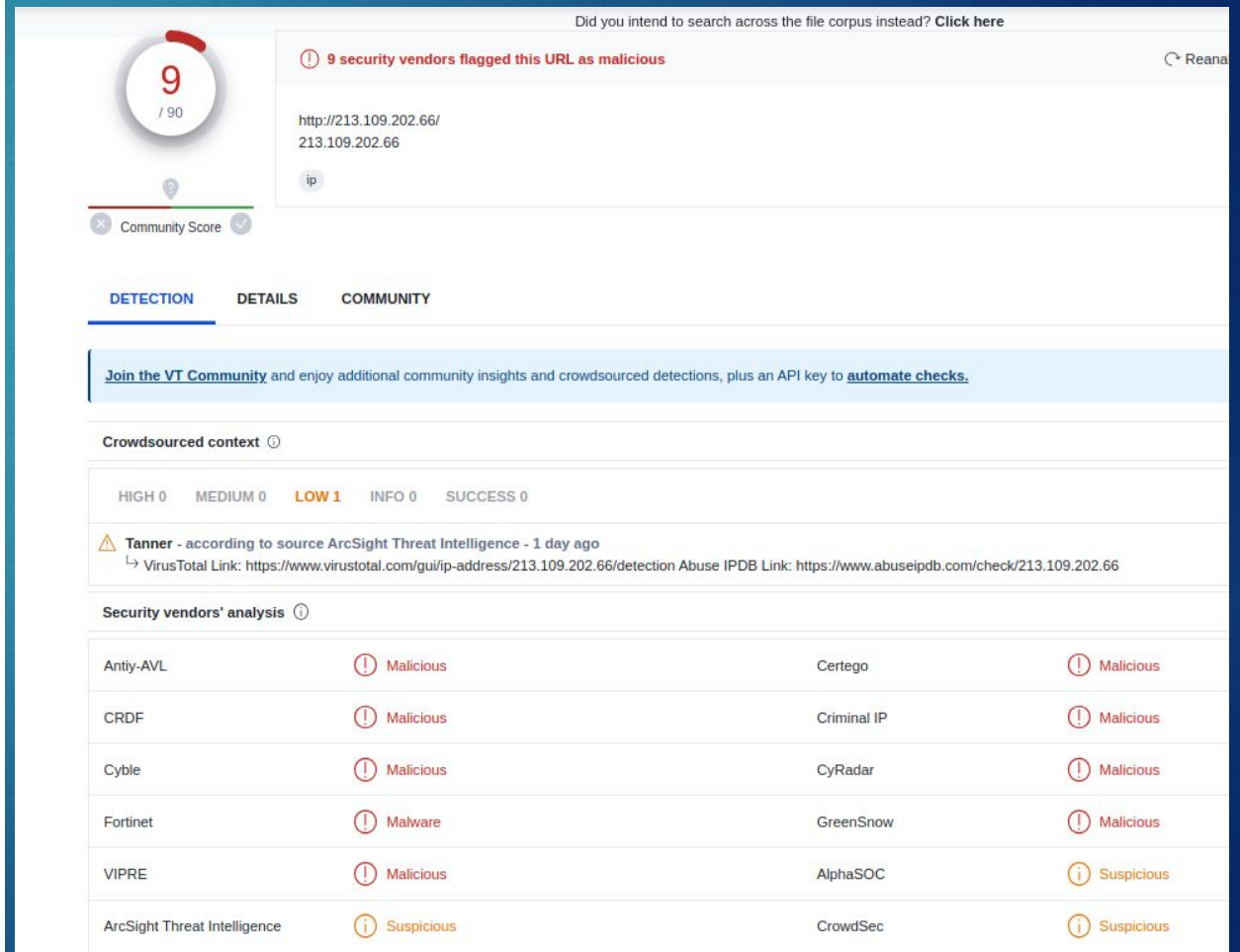




Ejemplos. Sitio Web maliciosos

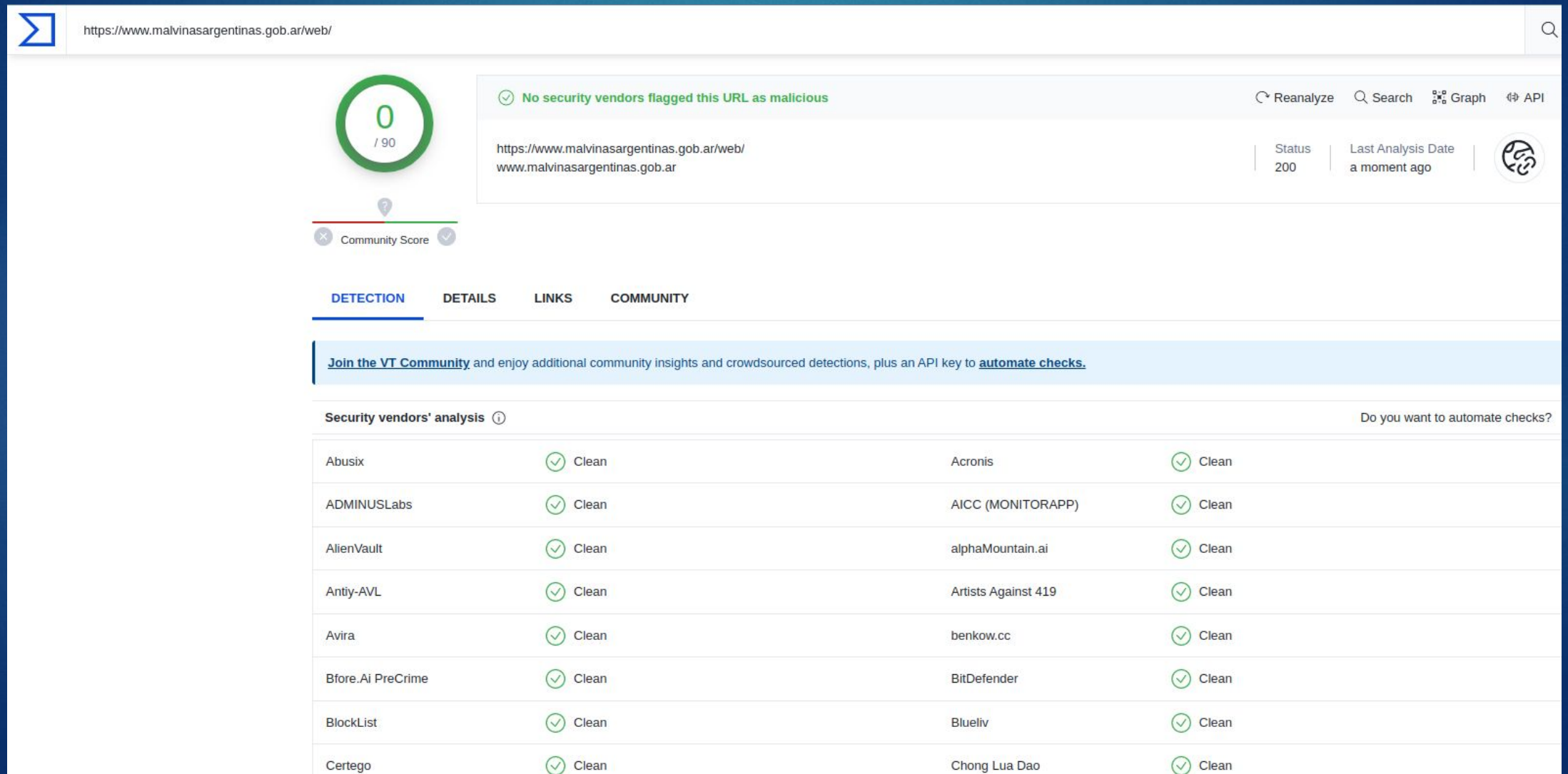
Investiga la reputación del sitio: Utiliza herramientas de seguridad en línea que proporcionen información sobre la reputación y la seguridad de una página web, como por ejemplo, virustotal.com.





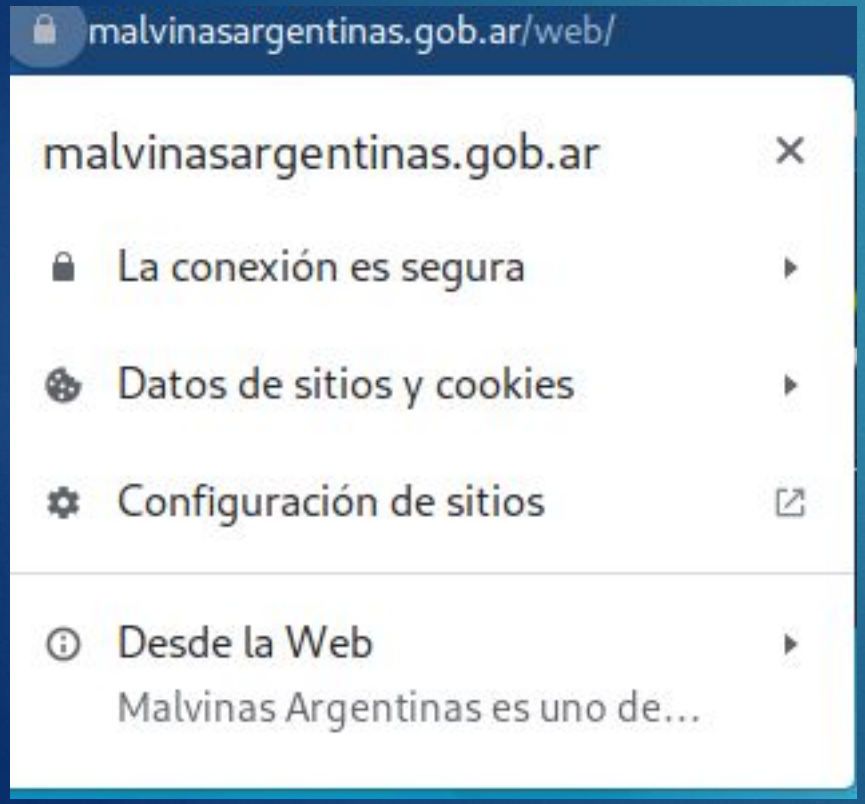
Ejemplos. Sitio Web maliciosos

Investiga la reputación del sitio: Utiliza herramientas de seguridad en línea que proporcionen información sobre la reputación y la seguridad de una página web, como por ejemplo, virustotal.com



Ejemplos. Sitio Web maliciosos

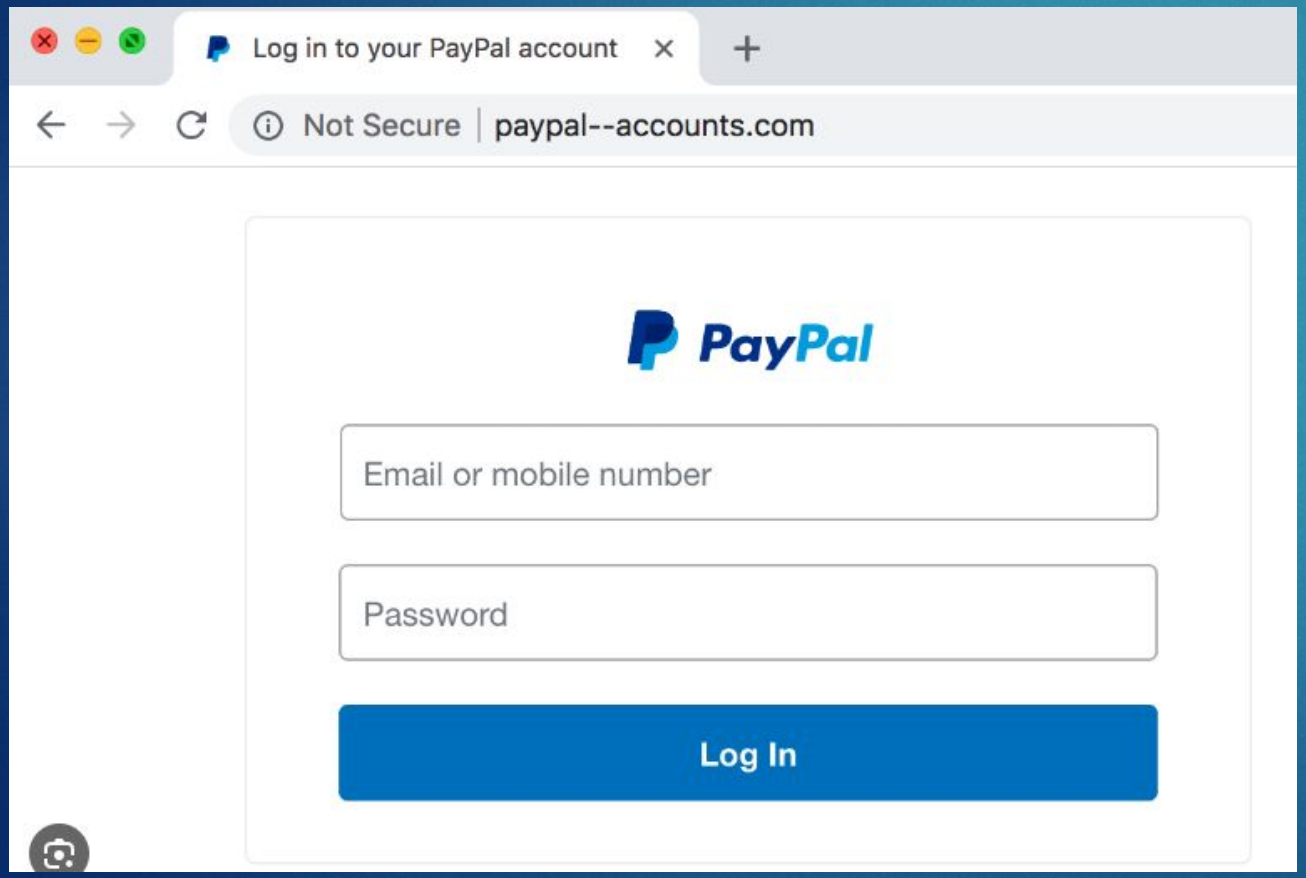
Comprueba el certificado SSL: Si la página web solicita información personal o financiera, verifica si tiene un certificado SSL válido. Esto se puede identificar por un candado en la barra de direcciones del navegador y por una URL que comienza con "https://"





Ejemplos. Sitio Web maliciosos

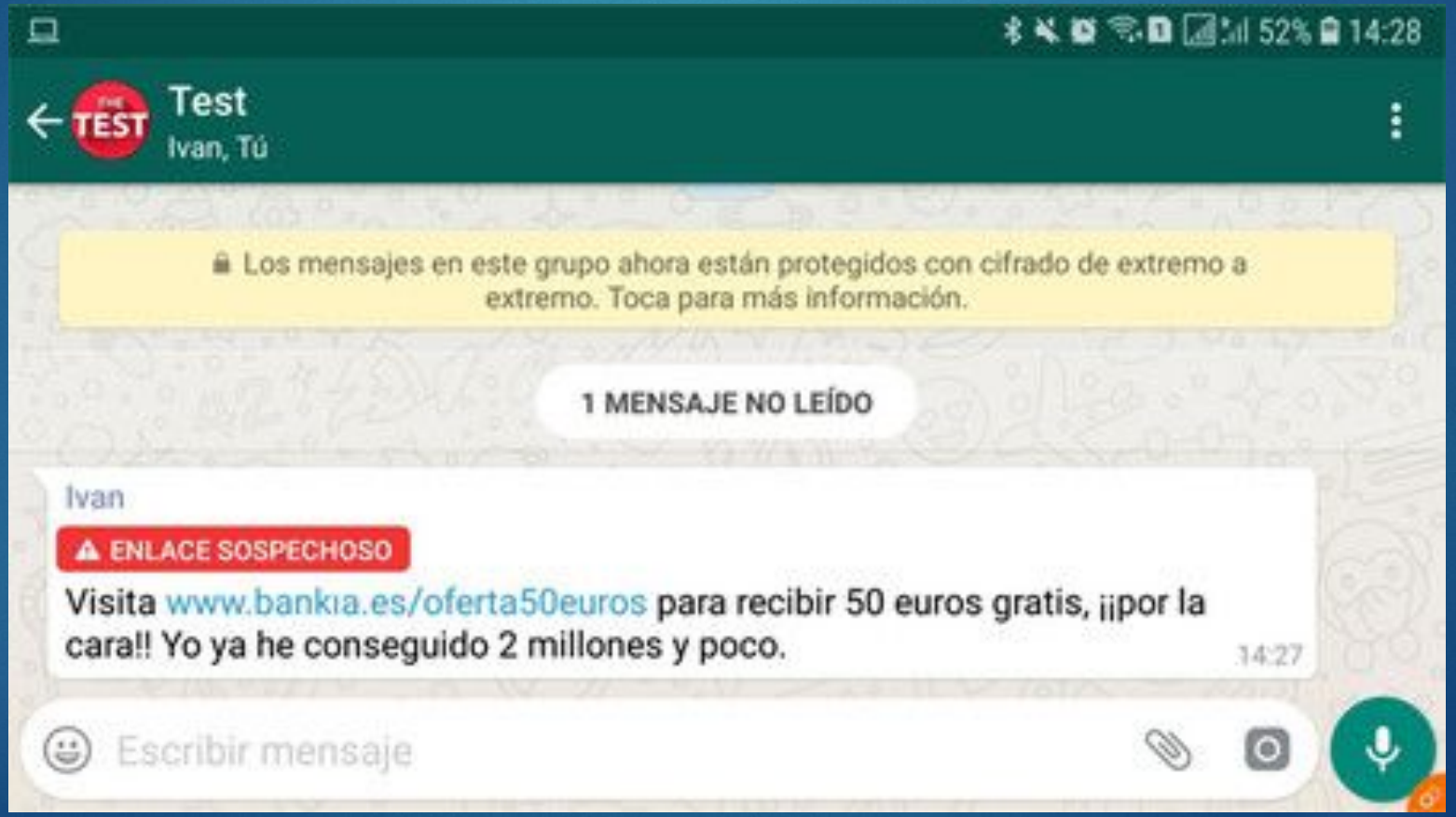
Analiza el diseño y el contenido: Si el diseño del sitio parece poco profesional, contiene muchos errores gramaticales o presenta anuncios intrusivos y sospechosos, es posible que sea una página web maliciosa. Además, presta atención a las solicitudes inusuales de información personal o financiera.





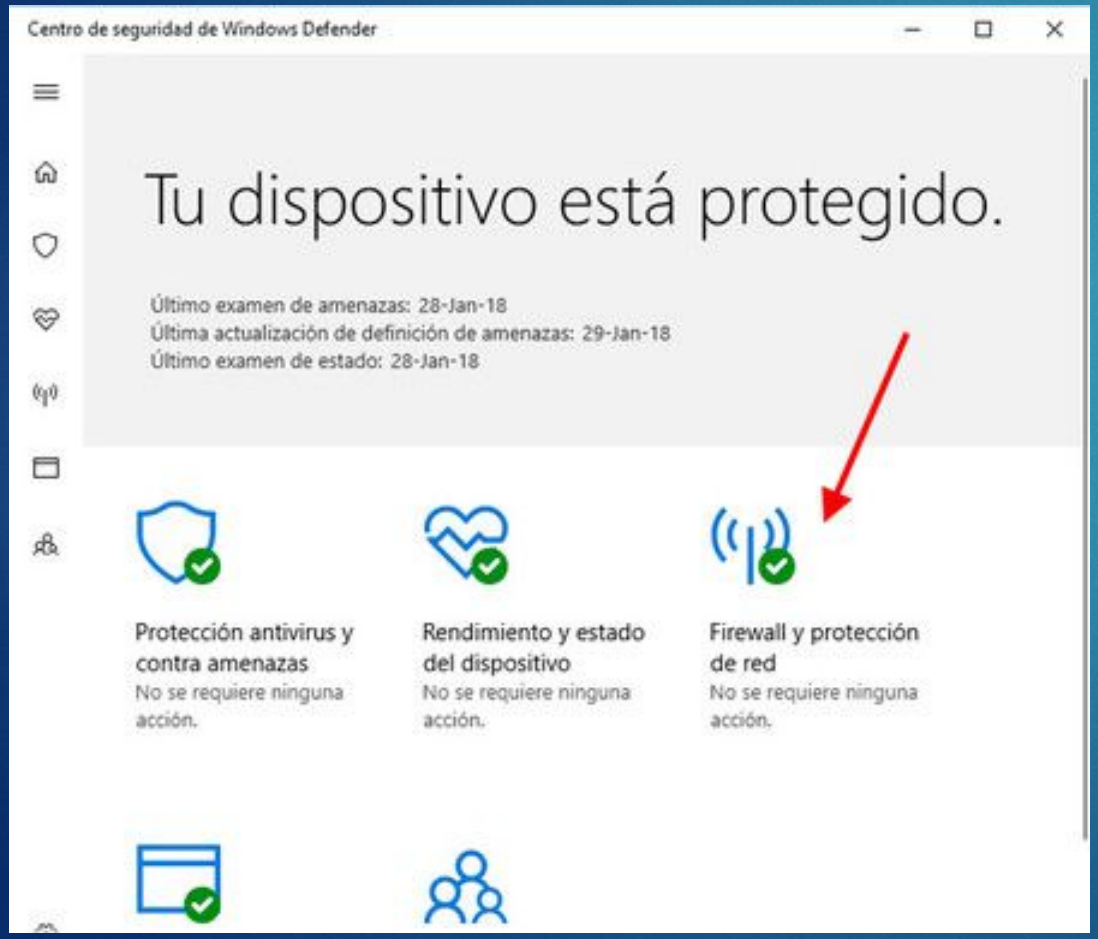
Ejemplos. Sitio Web maliciosos

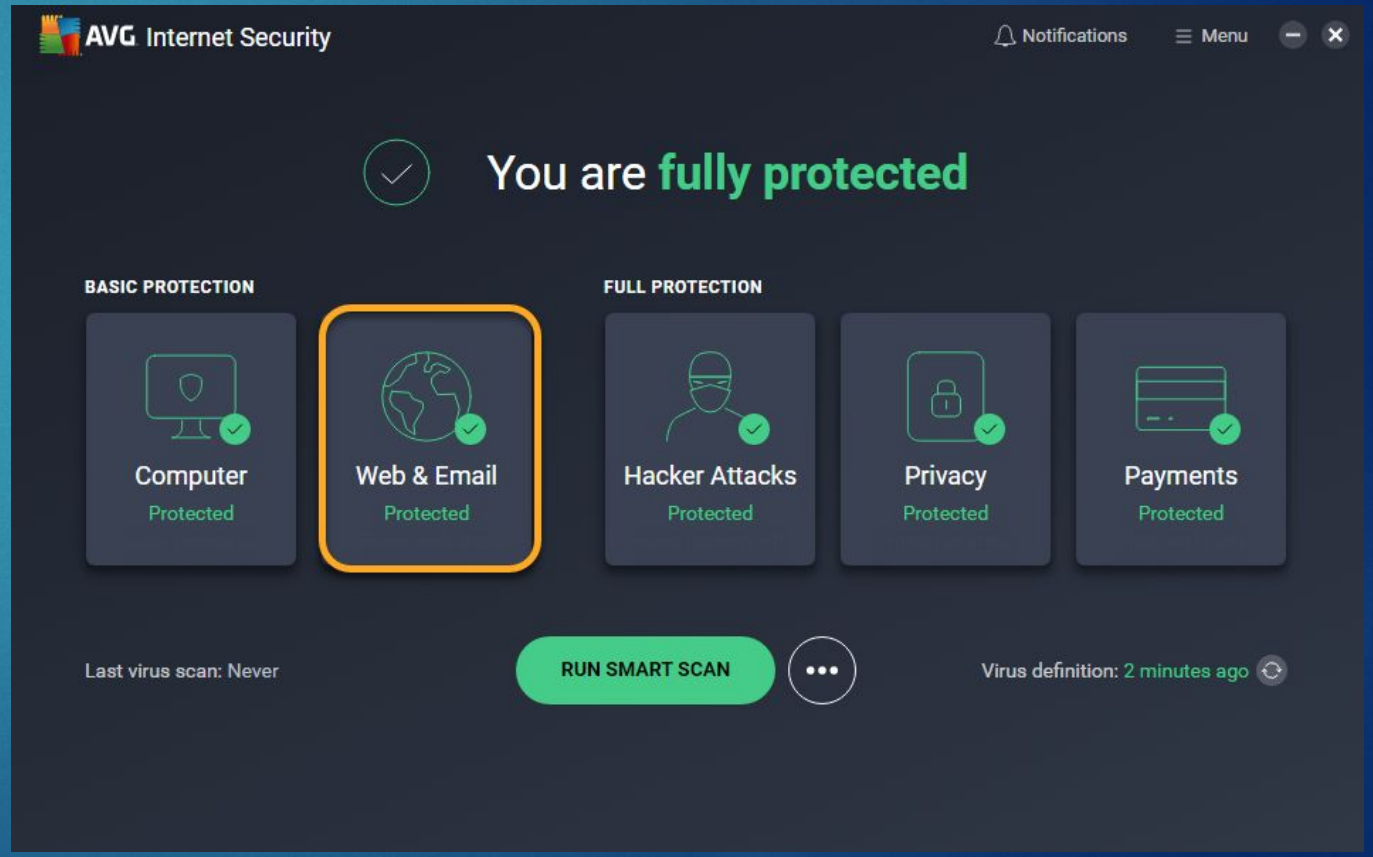
Evita enlaces desconocidos o sospechosos: No hagas clic en enlaces de fuentes no confiables, correos electrónicos no solicitados o mensajes sospechosos en redes sociales. Estos enlaces pueden redirigir a páginas web maliciosas.



Ejemplos. Sitio Web maliciosos

Utiliza herramientas de seguridad: Instala y mantén actualizado un software antivirus y un cortafuegos en tu dispositivo. Estas herramientas pueden ayudar a detectar y bloquear sitios web maliciosos conocidos.





Phishing Contramedida

Video de instalación de GoPhish:
https://www.youtube.com/watch?v=xjQEsS2s6yQ

Malware

Malware es software malicioso que puede:

– Infectar otras PCs
– Permitir el acceso remoto a la información de la PC
– Destruir información
– Robar información personal
–Hacer que nuestra PC ejecute acciones ordenadas por un tercero: enviar SPAM, saturar comunicaciones, etc.

Consideramos malware a cualquiera de los siguientes: Virus, Gusano, Troyano, Spyware, Keylogger, Backdoor, Ransomware

Malware

- El malware puede llegar **con** o **sin** nuestro consentimiento.

Sin nuestro consentimiento, infectando nuestro dispositivo:

- Al visitar un sitio web malicioso
- Al utilizar un pendrive infectando
- A través de la red a la que está conectada nuestro dispositivo

Con nuestro consentimiento:

- Instalando software pirata. (juegos, cracks, keygens)
- Siendo víctimas de ingeniería social.

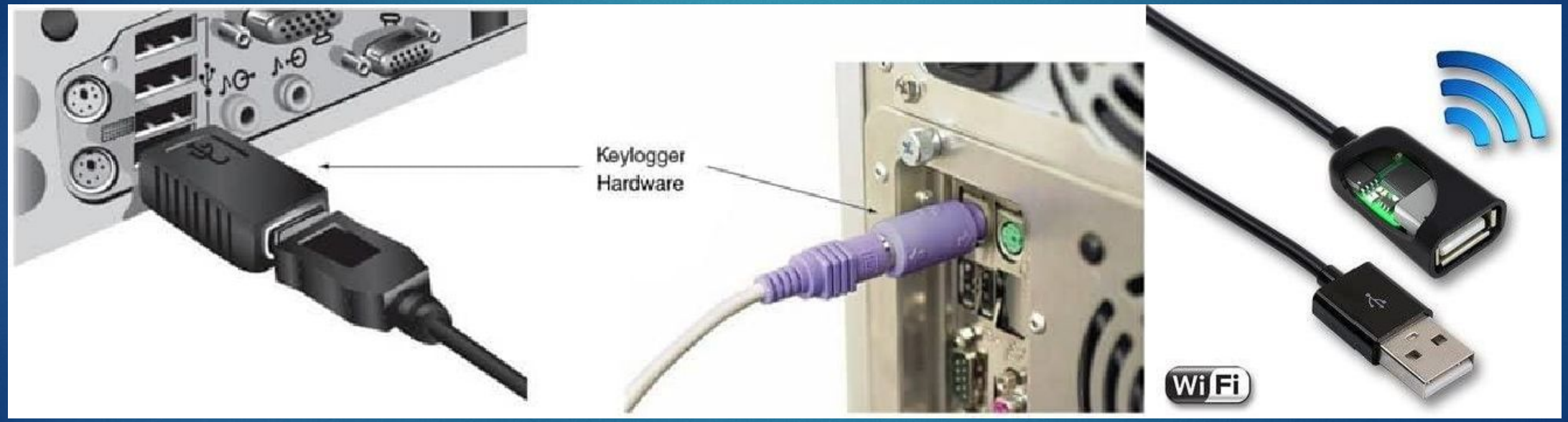
A veces, que un dispositivo esté infectado con un malware es como tener a alguien observando qué hacemos.

El malware puede saber: qué sitios visitamos, qué teclas presionamos, donde hacemos click,... todo.
Es por esto que debemos ser cuidadosos con el dispositivo utilizado para acceder a los sistemas críticos para nosotros o para la organización: Homebanking, Paypal, Webmail.

Evitar usar PCs no confiables (ubicadas en lugares públicos, PCs en las que se instaló software pirata)

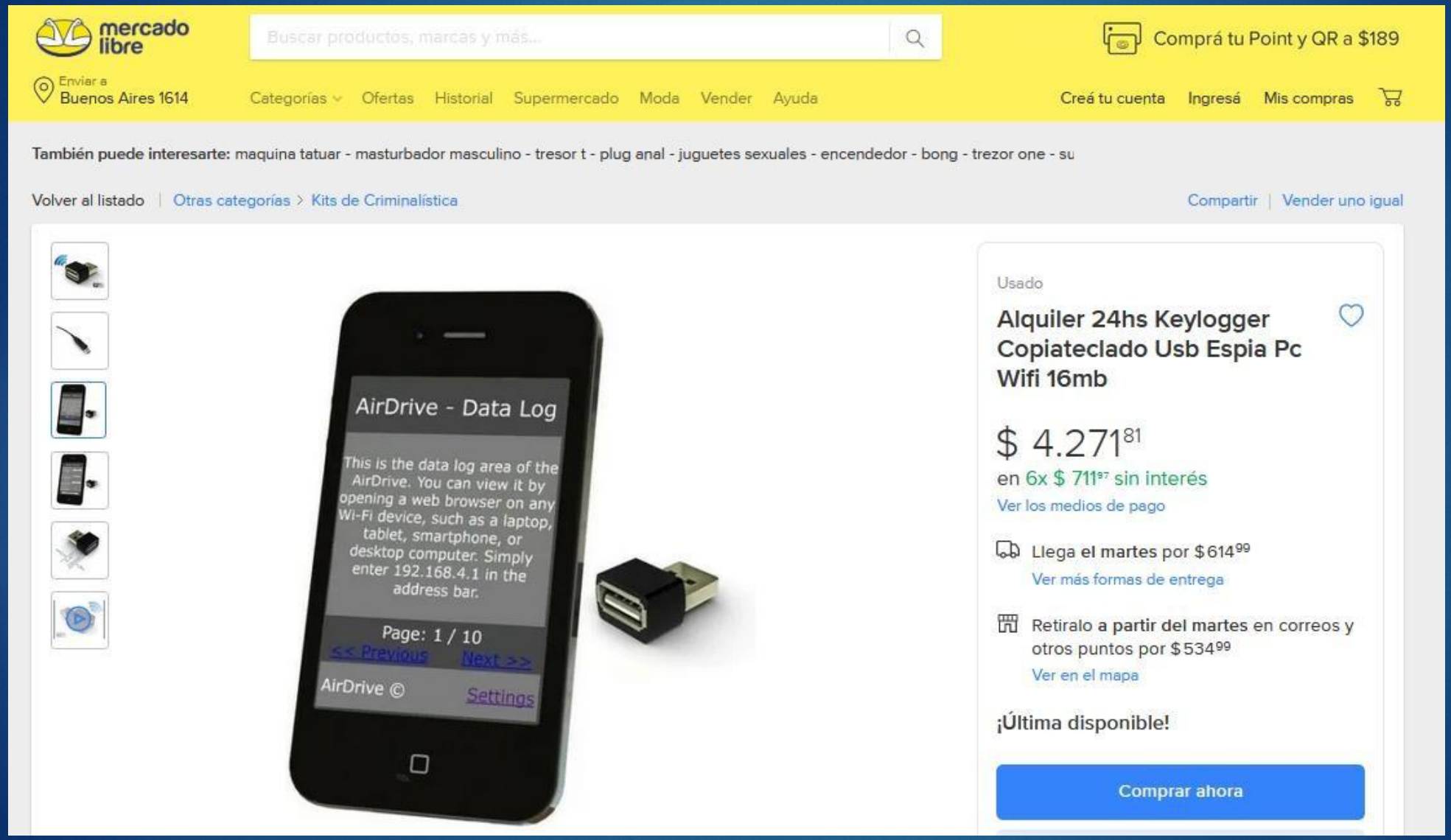
Keyloggers

- Software o hardware que tiene la capacidad de almacenar lo que se tipea.
  Los keyloggers por software también permiten, por ejemplo, capturar pantallas cuando el usuario “cliquea”..



Caso de teclado en pantalla

KeyLogger Wifi



https://articulo.mercadolibre.com.ar/MLA-795637872-keylogger-copiateclado-usb-espia-pc-wifi-16gb-criminalistica-_JM#position=48&search_lay

Botnets

¿Qué es una botnet?

Es una red de bots, que son hosts infectados (combinan aspectos de virus, troyanos, gusanos y rootkits: control remoto, propagación, etc)

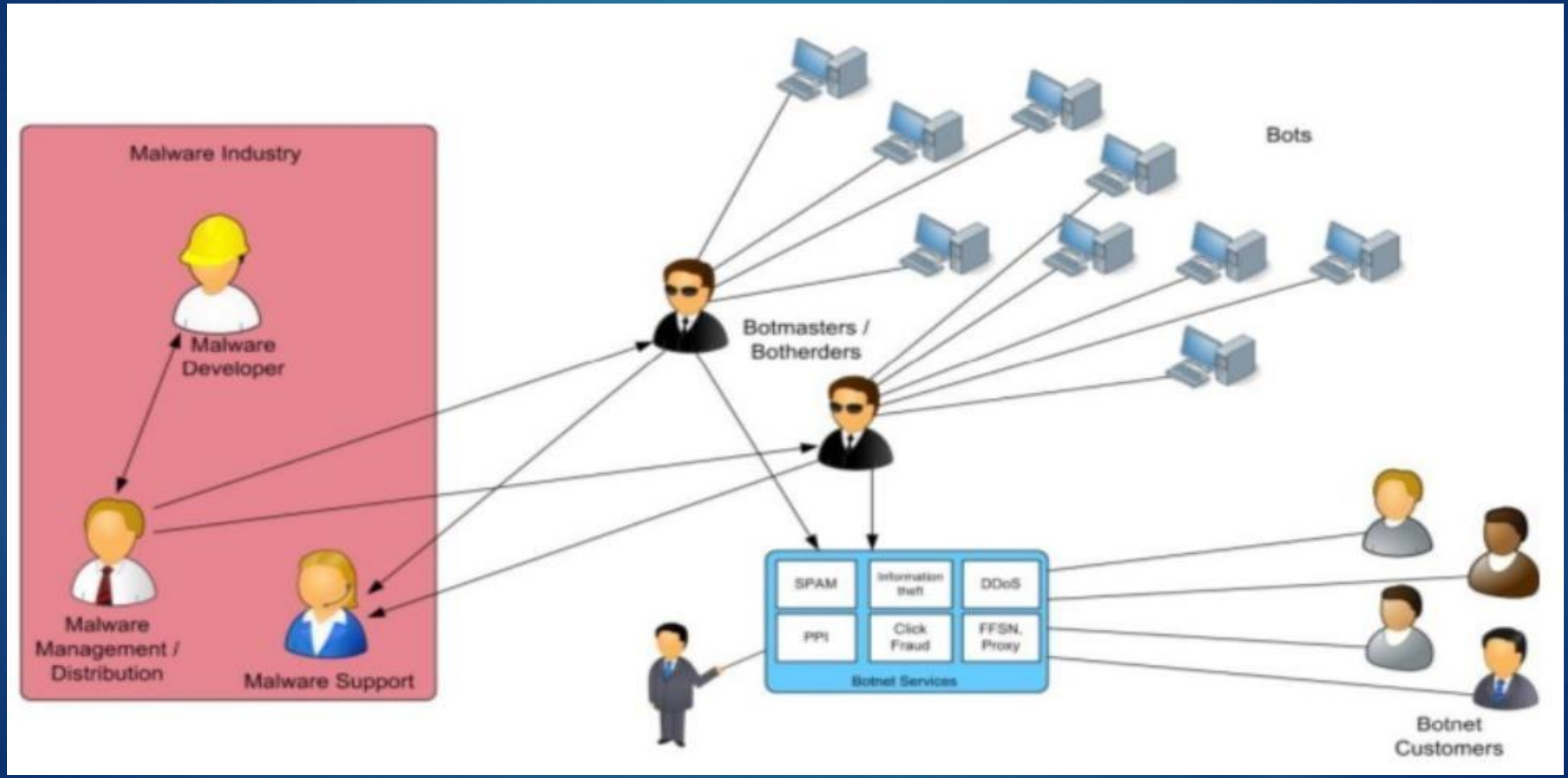
Hay una entidad de control conocido como Servidor “Command & Control” manejado por “bot master/herder” (una persona o grupo)

Realizan actividades maliciosas, como por ej:

- Robo de credenciales
- Envío de SPAM
- DDOS



Modelo económico del Malware con Botnets

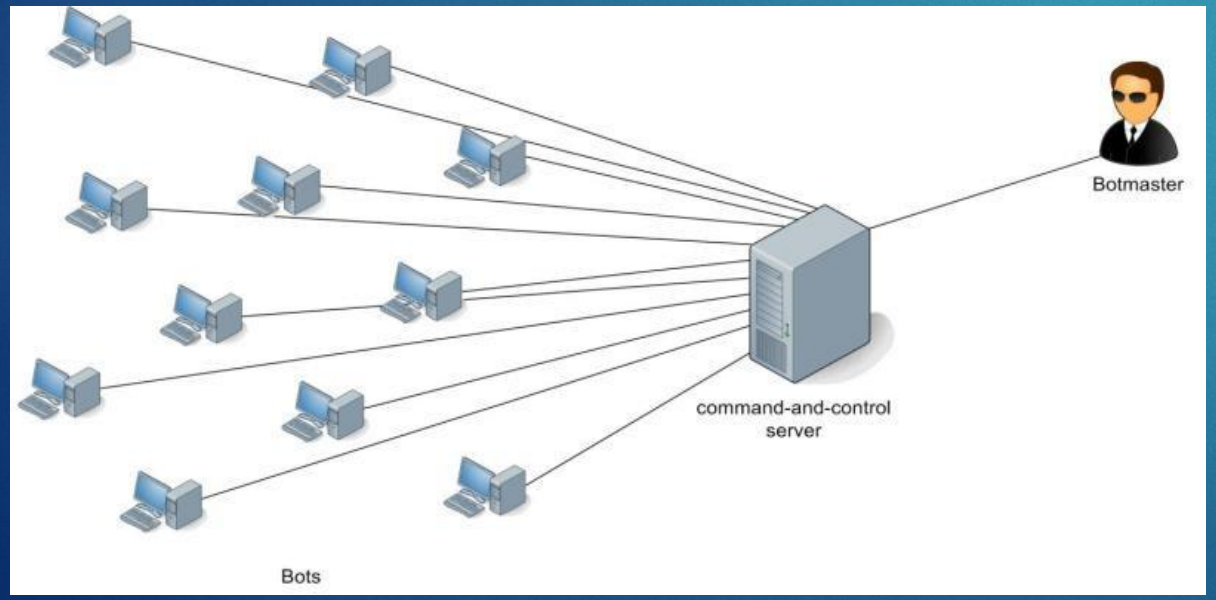


- Servicio Antibotnet España: https://www.incibe.es/protege-tu-empresa/herramientas/servicio-antibotnet

Tipo de Botnets

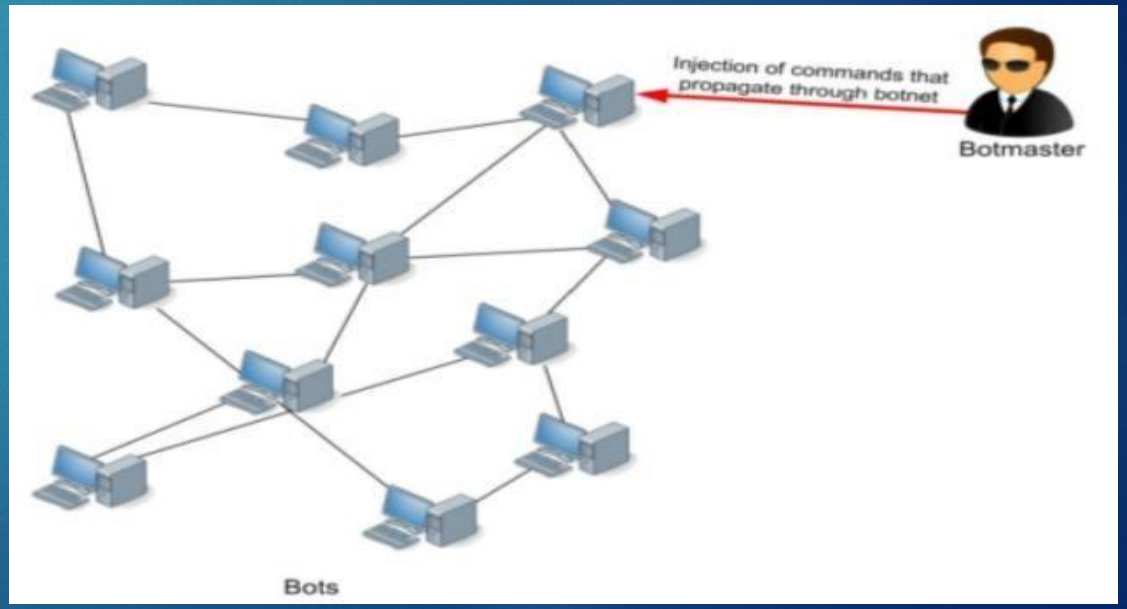
Arquitectura centralizada

- Los bots establecen comunicación con un único servidor (o jerarquía de servidores) (C&C)
- En sus inicios, basadas en el funcionamiento del protocolo IRC
- Es simple coordinar y monitorear la botnet
- El protocolo de comunicación puede ser IRC, HTTP, HTTPS



Arquitectura descentralizada

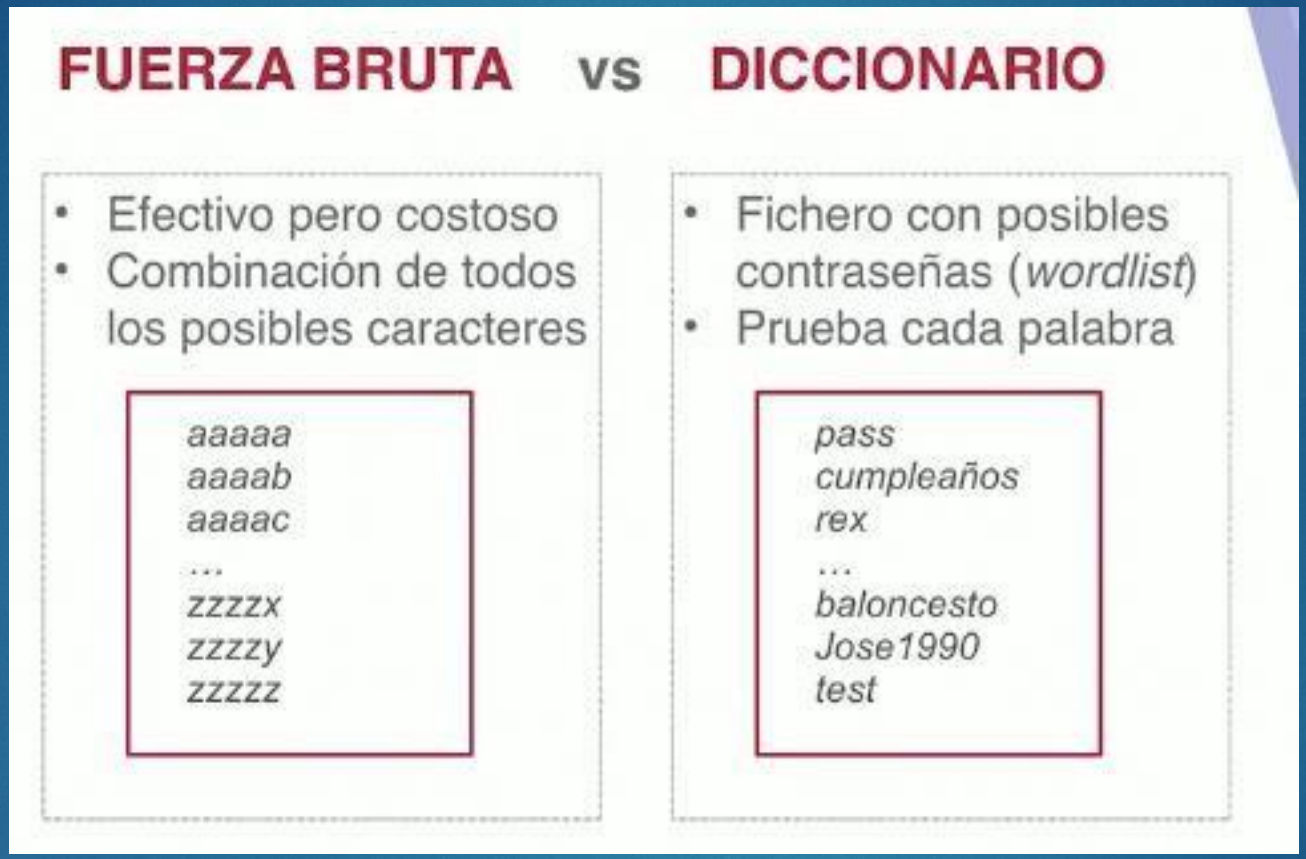
- También conocidas como botnets P2P
- El botmaster inyecta los comandos a un bot (usando el protocolo de comunicación de la botnet o a través de una actualización (los bots intercambian su número de versión y en caso de ser necesario se actualizan a partir del más nuevo))
- Es difícil localizar al botmaster → alto grado de anonimato



Accesos no autorizados

Ataques a Contraseña

Consiste en la prueba metódica de contraseñas para lograr el acceso a un sistema, siempre y cuando la cuenta no presente control de intentos fallidos de logueo.



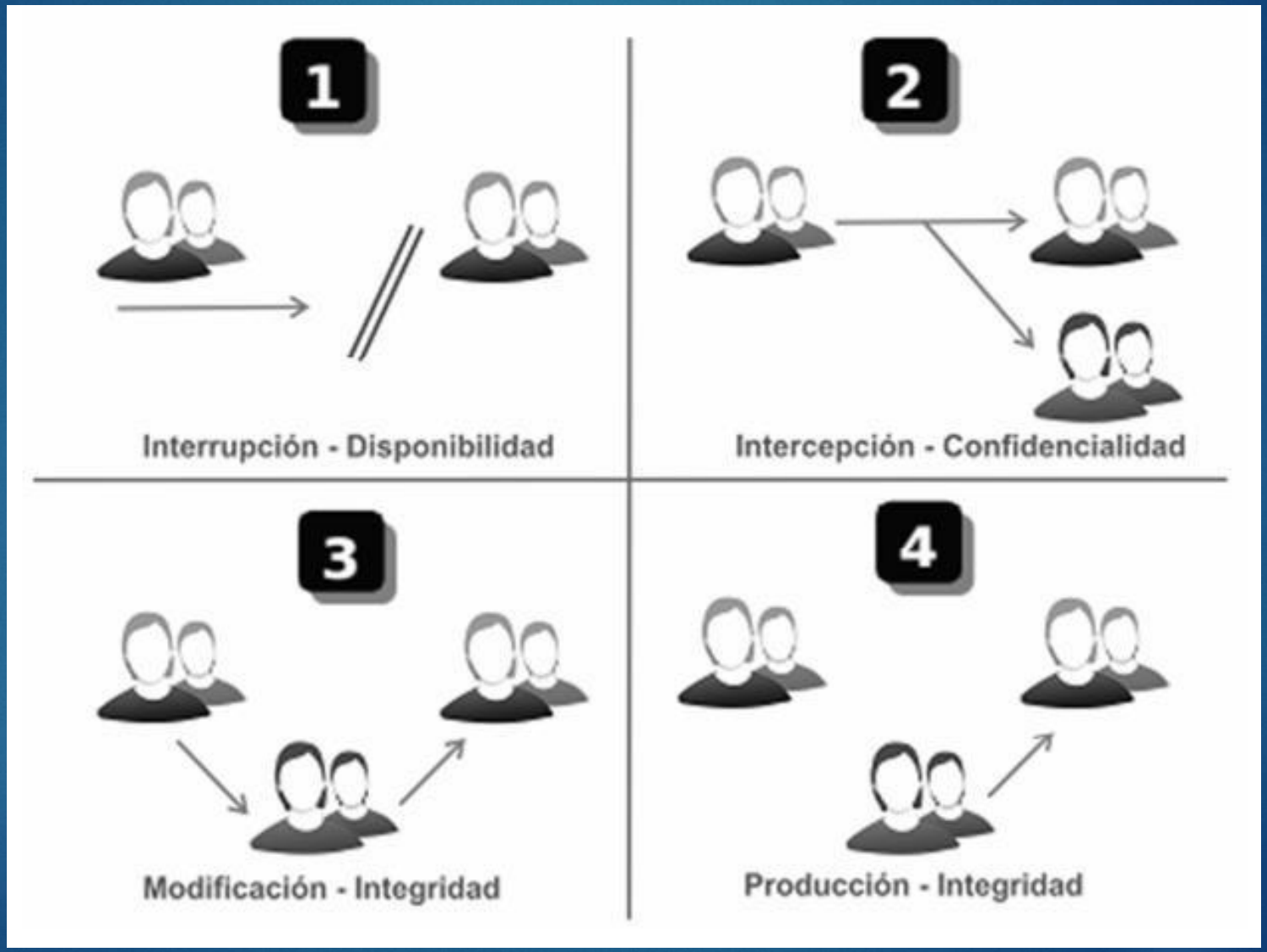
Por fuerza bruta

una herramienta generará combinaciones de letras, números y símbolos formando posibles contraseñas y probando una a una en el login del sistema.

Por diccionario:

Existiendo un diccionario de palabras, una herramienta intentará acceder al sistema probando una a una las palabras incluidas en el mismo.

Tipos de Ataques



Tipos de Ataques

- **Interrupción:** Un recurso del sistema o de la red, deja de estar disponible debido al ataque.
- **Modificación:** La información de la que se dispone, es modificada sin autorización y por lo tanto deja de ser válida.
- **Intercepción:** El intruso accede a la información de nuestros equipos, o a la información que enviamos por la red.
- **Fabricación:** Consiste en crear un producto que sea difícil de distinguir del auténtico y que es utilizado para hacerse con la información confidencial de los usuarios.

Cómo enfrentamos las amenazas

Como **administradores desarrolladores:**

Como **responsables de seguridad en nuestra organización:**

Como **usuarios:**

Cómo enfrentamos las amenazas

Como **administradores desarrolladores:**

Siguiendo las buenas prácticas de seguridad que indican los estándares/normas nacionales e internacionales

Como **responsables de seguridad en nuestra organización:**

Como **usuarios:**

Cómo enfrentamos las amenazas

Como **administradores desarrolladores:**

Siguiendo las buenas prácticas de seguridad que indican los estándares/normas nacionales
e internacionales

Como **responsables de seguridad en nuestra organización:**

–Concientización de los usuarios/personal de la organización.
–Especialización en temas relacionados a seguridad
de la Información
– Implementación de controles adecuados

Como **usuarios:**

Cómo enfrentamos las amenazas

- Elegir una clave segura.
- Proteger adecuadamente la clave.
- Descargar aplicaciones sólo desde sitios confiables.
- Utilizar antivirus y firewalls personales.
- Mantener el sistema actualizado (SO, aplicaciones, antivirus!!)
- No abrir adjuntos que provienen de orígenes no confiables o conectarse directamente a urls contenidas en los mails.

Como **responsables de seguridad en nuestra organización:**

- Concientización de los usuarios/personal de la organización.
- Especialización en temas relacionados a seguridad de la Información
- Implementación de controles adecuados

Como **usuarios:**

Siguiendo las buenas prácticas de seguridad que indican los estándares/normas nacionales e internacionales

Ataques: clasificación según su tipo

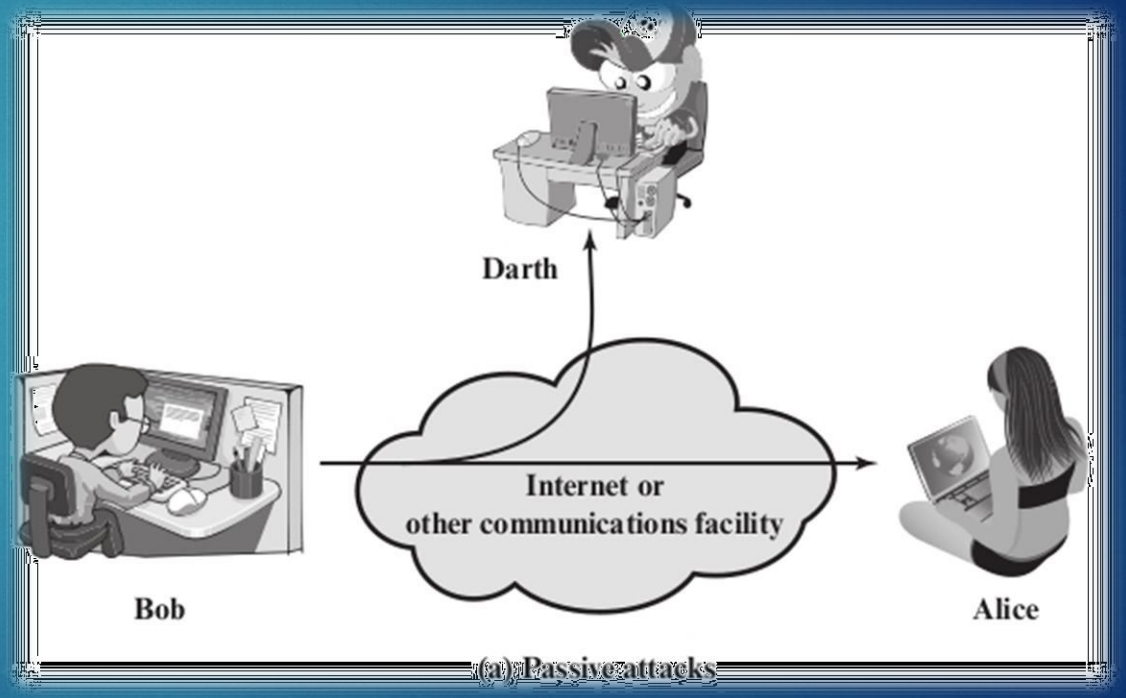
Ataque pasivo

Intento de aprender o hacer uso de la información proveniente de un sistema, que no afecta a los recursos del mismo.

- El objetivo del ataque pasivo es obtener información.
- Importa más la prevención que la detección.

Tipos

- Publicación de contenidos.
- Análisis de tráfico.

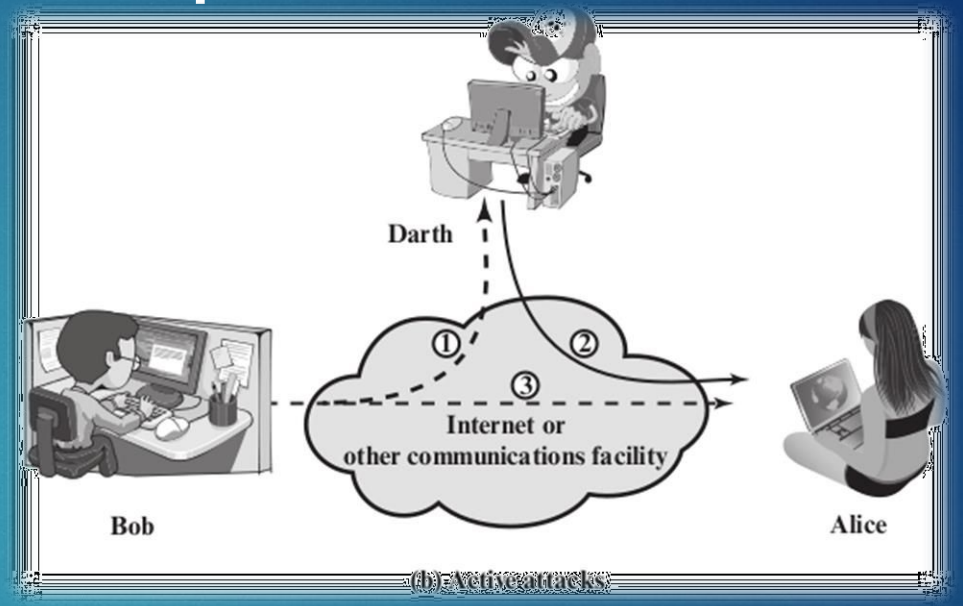


Ataques: clasificación según su tipo

Ataque activo

Intento de alterar los recursos del sistema o afectar su operación.

- Involucra modificar el flujo de datos o la creación de datos falsos y agregarlos al flujo.
- Es difícil prevenirlos dada la gran variedad de vulnerabilidades. Cuando ocurren estos ataques, en general se detecta y se intenta recuperarse.



Tipos:

- Enmascaramiento: path 2 activo.
- Retransmisión: paths 1, 2, 3 activos.
- Modificación de mensajes: paths 1 y 2 activos.
- Denegación de servicio (DoS): path 3 activo.

Ataques: clasificación según su origen

Ataque interno

Iniciado por una entidad dentro del perímetro de seguridad (un "interno"). El interno está autorizado para acceder a los recursos del sistema, pero los utiliza de una manera no aprobada por quienes otorgaron la autorización.

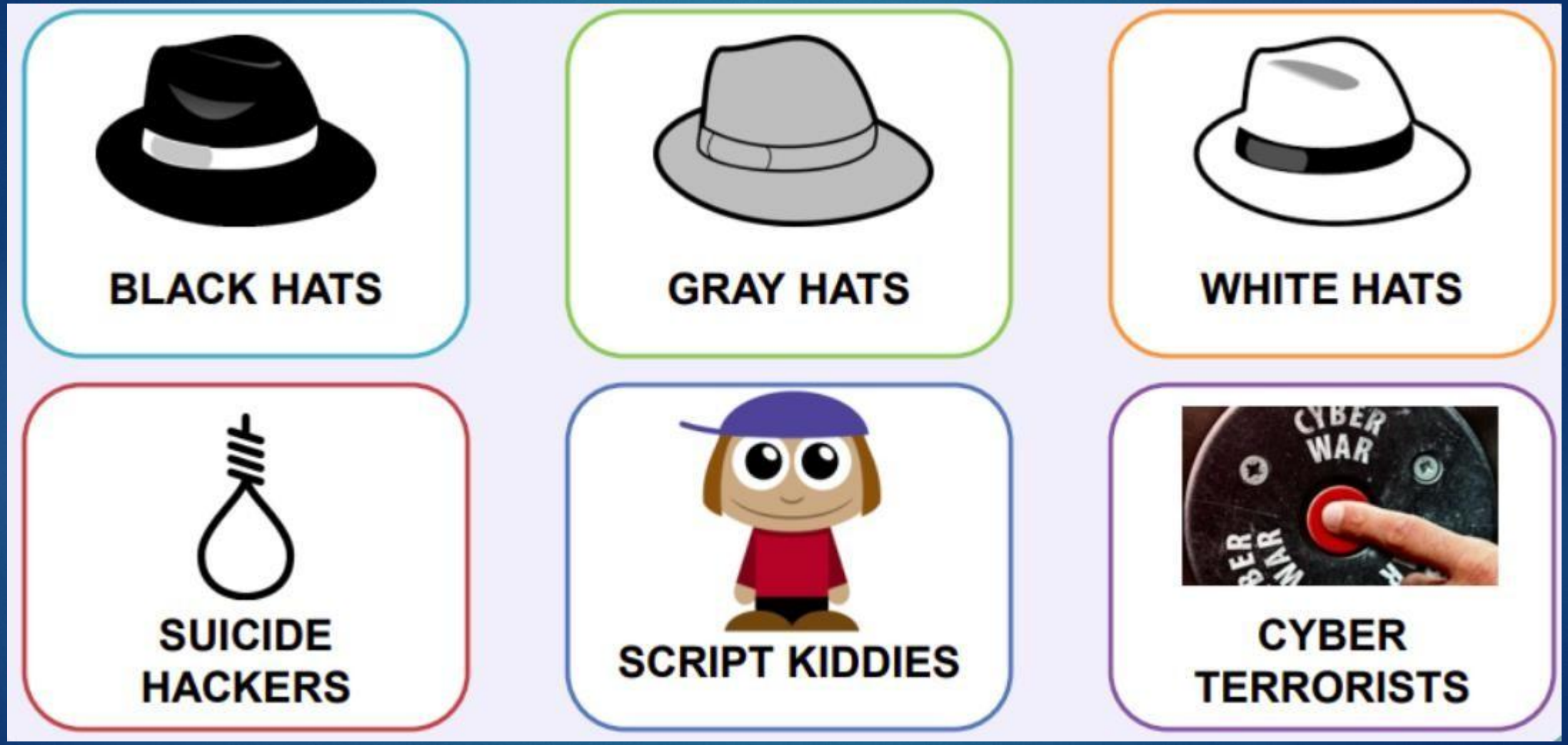


Ataque externo

Iniciado desde fuera del perímetro, por un usuario no autorizado o ilegítimo del sistema (un “forastero”). En Internet, los posibles atacantes externos van desde bromistas aficionados a delincuentes organizados, terroristas internacionales y gobiernos hostiles.



Tipos de hackers



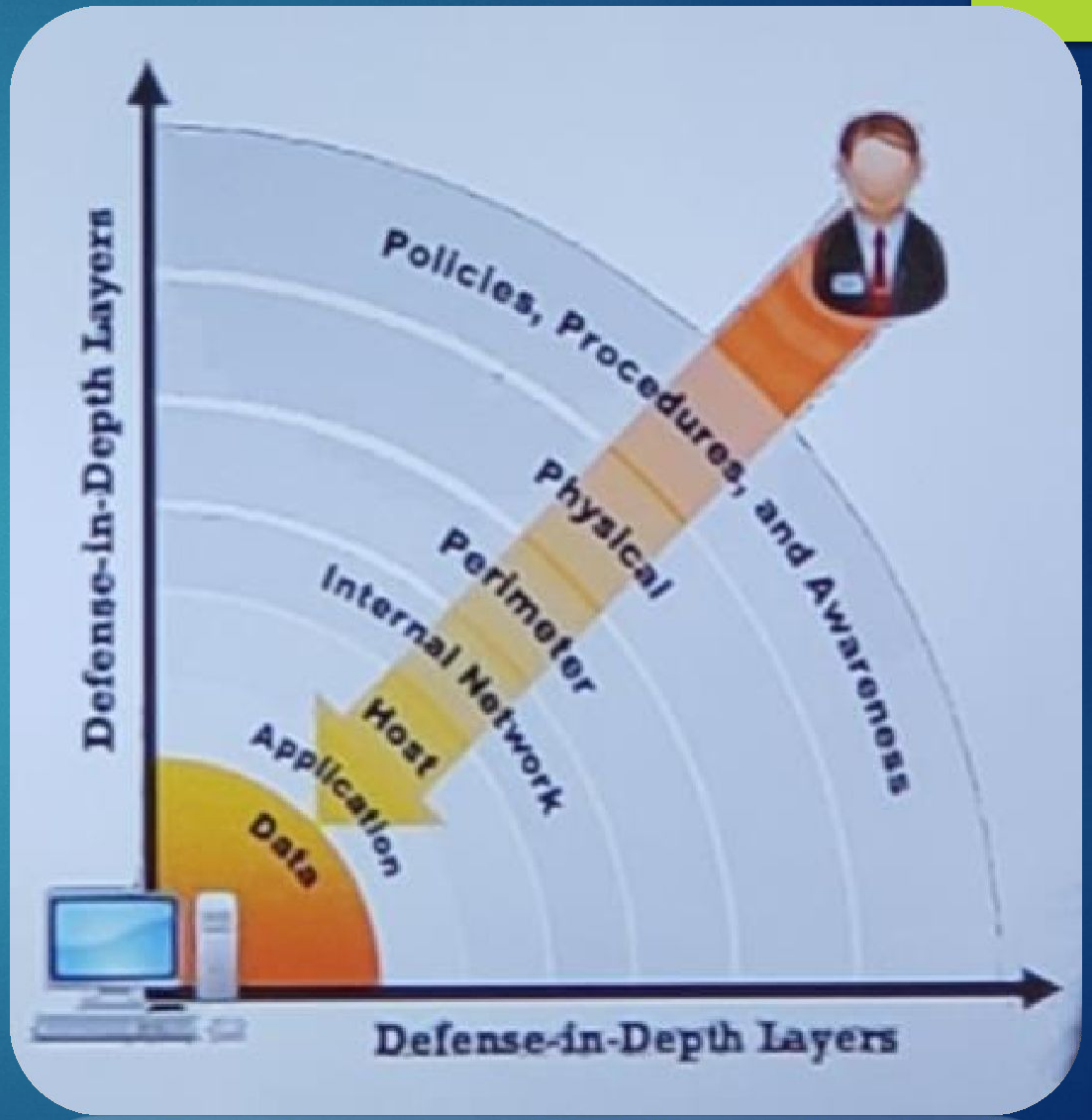
Conceptos de seguridad informática

Atacantes

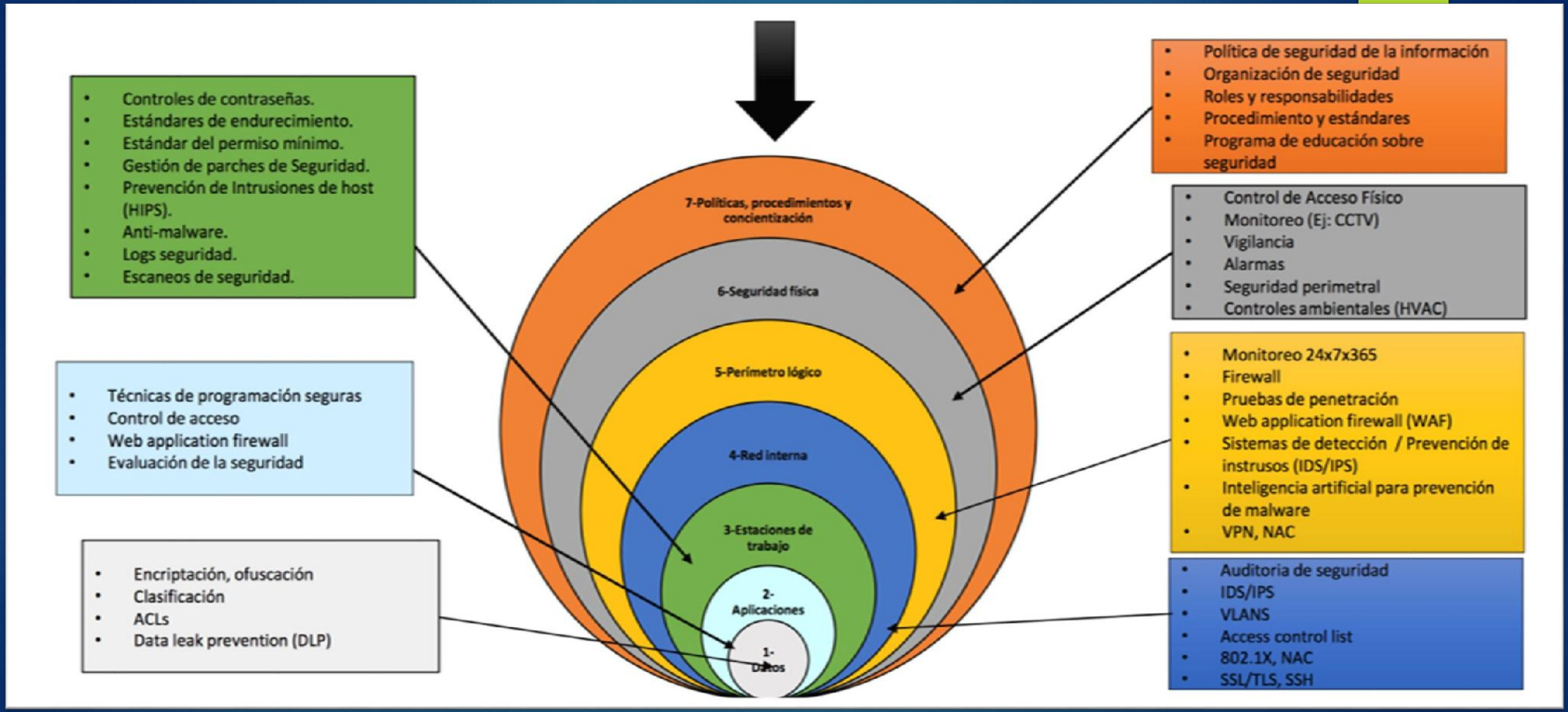
- **Hackers:** Son normalmente expertos informáticos, que quieren descubrir vulnerabilidades de los sistemas por gusto, sin motivación económica ni dañina.
- **Crackers:** Son las personas que rompen la seguridad del sistema con intención maliciosa, para dañarla u obtener beneficios económicos.
- **Sniffers:** Son expertos en redes que analizan el tráfico de la red, para obtener información extrayéndola de los paquetes que se transmiten por la red.
- **Lammers:** Son gente joven sin muchos conocimientos informáticos que se consideran a si mismos hackers y presumen de ello.
- **Ciberterrorista**: Son expertos informáticos que trabajan para países u organizaciones como espías si saboteadores informáticos.
- **Programadores de virus:** Estas personas deben ser expertos en programación redes y sistemas., que crean programas dañinos que afectan a aplicaciones y a sistemas.
- **Carders:** Son personas que se dedican a ataques de sistemas de tarjetas como cajeros automáticos.

Estrategia Defensiva

"Seguridad no es "hacking", así como un militar que conoce tanto de operaciones ofensivas como defensivas a la hora de decidirse por una defensa, aplica herramientas, tácticas y metodologías defensivas; en la defensa de un sistema informático se deben respetar esas mismas ideas, y no nos sirve con conocer únicamente técnicas de escaneo, intrusión, evasión, exploits, crack, etc… debemos saber implantar una adecuada ***estrategia defensiva*** *justamente contra estos acciones".*



Defensa en capas o profundidad

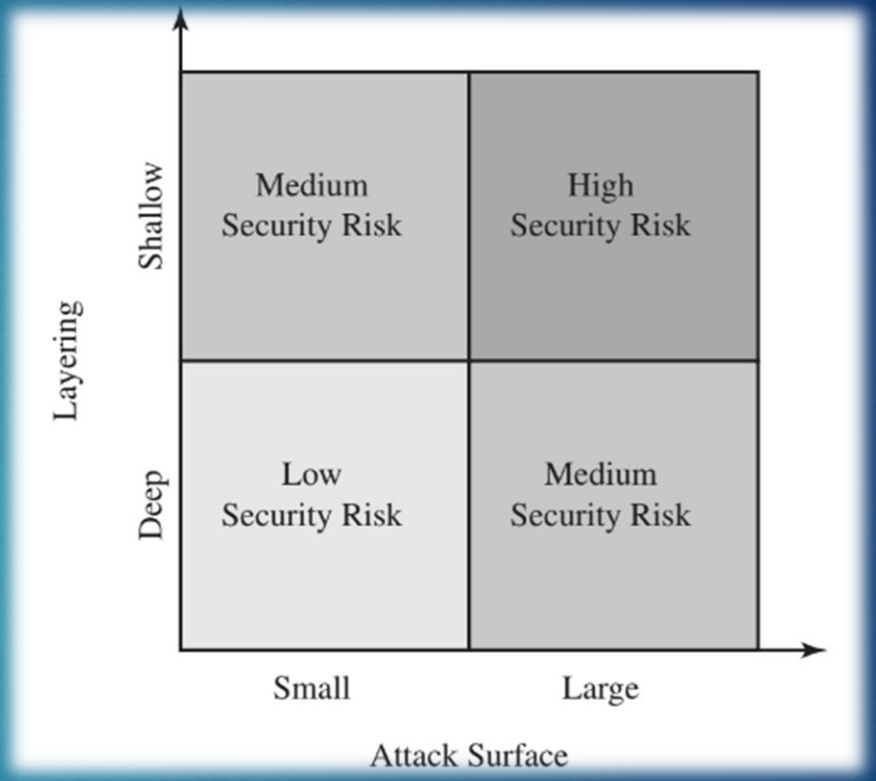


Superficies de ataque

Superficie de ataque
La superficie de ataque consiste en las vulnerabilidades de un sistema que pueden ser alcanzadas y explotadas.

Ejemplos:

- Puertos abiertos.
- Servicios fuera de un firewall.
- Código que procesa datos.
- Interfaces, SQL, formularios web.
- Un empleado.
- Un Datacenter.



El **hardening** (en inglés “endurecimiento”) consiste en reducir la superficie de vulnerabilidad, evitando así posibles ataques.

Superficies de ataque

Las superficies de ataque se pueden clasificar de la siguiente manera:

- **Superficie de ataque física (**Factor físico)**.** Edificios / instalaciones.
- **Superficie de ataque de red (**Factor lógico)**.** Vulnerabilidades en una red de una organización, redes WAN, o Internet.
- **Superficie de ataque de software (**Factor lógico)**.** Vulnerabilidades en una aplicación, utilitario, o sistema operativo. Un foco particular en esta categoría
- **Superficie de ataque humana** (Factor humano). Vulnerabilidades creadas por personas tanto internas como externas.

Analizar las superficies de ataque y generar un **modelo de amenazas** es una técnica útil para evaluar la **escala y la severidad** de las amenazas de un sistema. Una vez que se ha hecho un mapeo sistemático de las amenazas y las superficies de ataque están definidas, los diseñadores de sistemas pueden buscar formas de **reducir la superficie**.

Modelo de amenazas

Un modelo de amenazas

Es en esencia una representación estructurada de toda la información que afecta a la seguridad de una aplicación.

El modelado de amenazas se aplica mejor **de forma continua a lo largo de un proyecto de desarrollo de software**. El proceso es esencialmente el mismo pero en diferentes niveles de abstracción, aunque la información se vuelve más y más granular durante todo el ciclo de vida. Lo ideal es que un modelo de amenazas de alto nivel debe estar **definido en la fase de planificación, y luego refinado a lo largo del ciclo de vida**.

Pasos genéricos

- Alcance de la evaluación
- Modelado del sistema
- Identificación de amenazas
- Identificación de vulnerabilidades
- Examinación del historial de amenazas
- Evaluación del impacto en el negocio / tecnico
- Desarrollo de un plan de respuestas ante amenazas a la seguridad.

Análisis mediante Arboles de Ataques

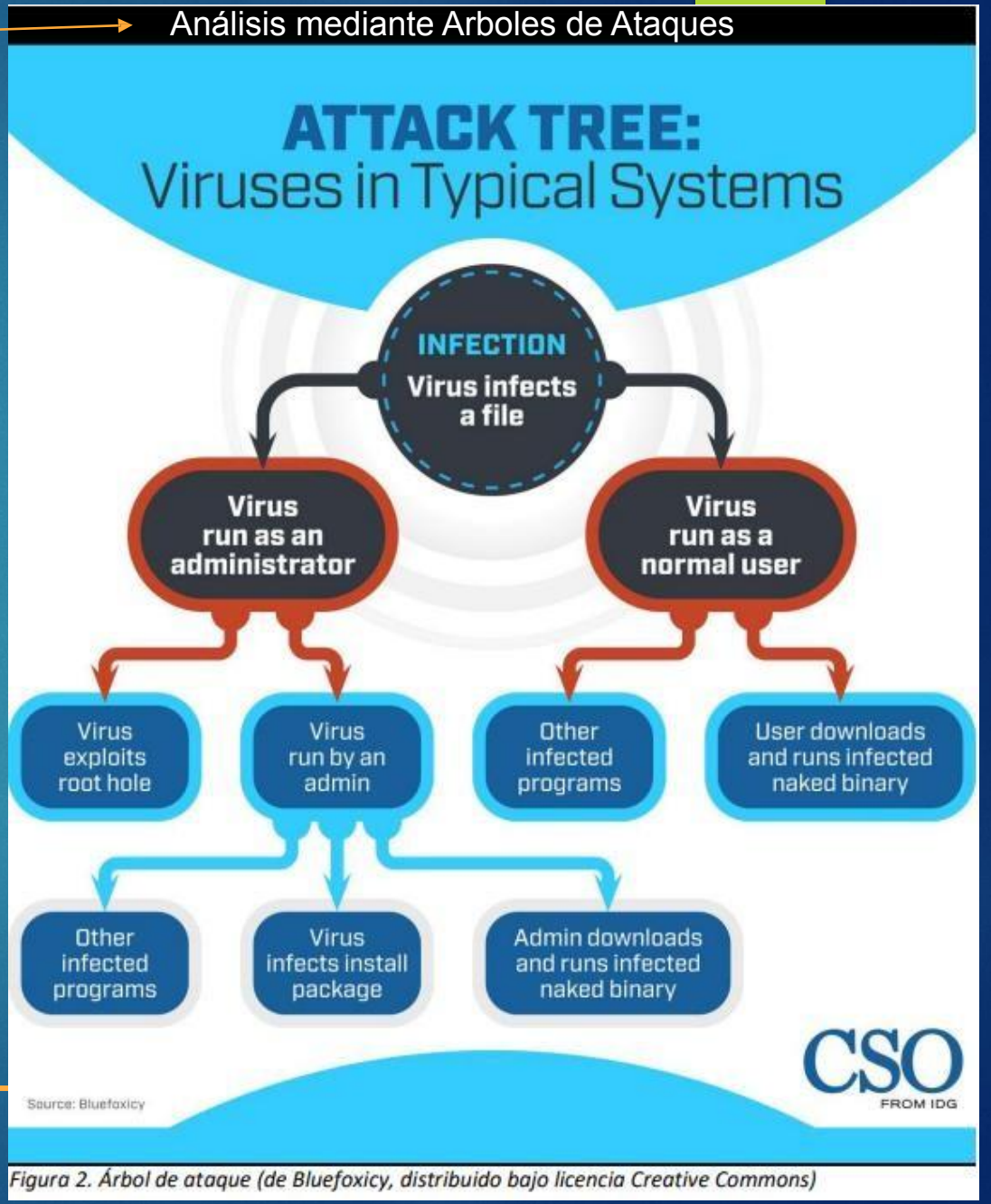


Figura 2. Árbol de ataque (de Bluefoxicy, distribuido bajo licencia Creative Commons)

Propósito de un modelo de amenazas

Debe responder cuatro preguntas:

1. ¿En qué estamos trabajando?
2. ¿Qué puede salir mal?
3. ¿Qué estamos haciendo al respecto?
4. ¿Hicimos un buen trabajo?

Debe contener cuatro pasos generales:

1. Descomponer la aplicación o infraestructura
2. Determinar las amenazas
3. Determinar contramedidas y mitigaciones
4. Clasificar las amenazas

Metodologías principales de modelado de amenazas:

1. STRIDE
2. DREAD
3. PASTA

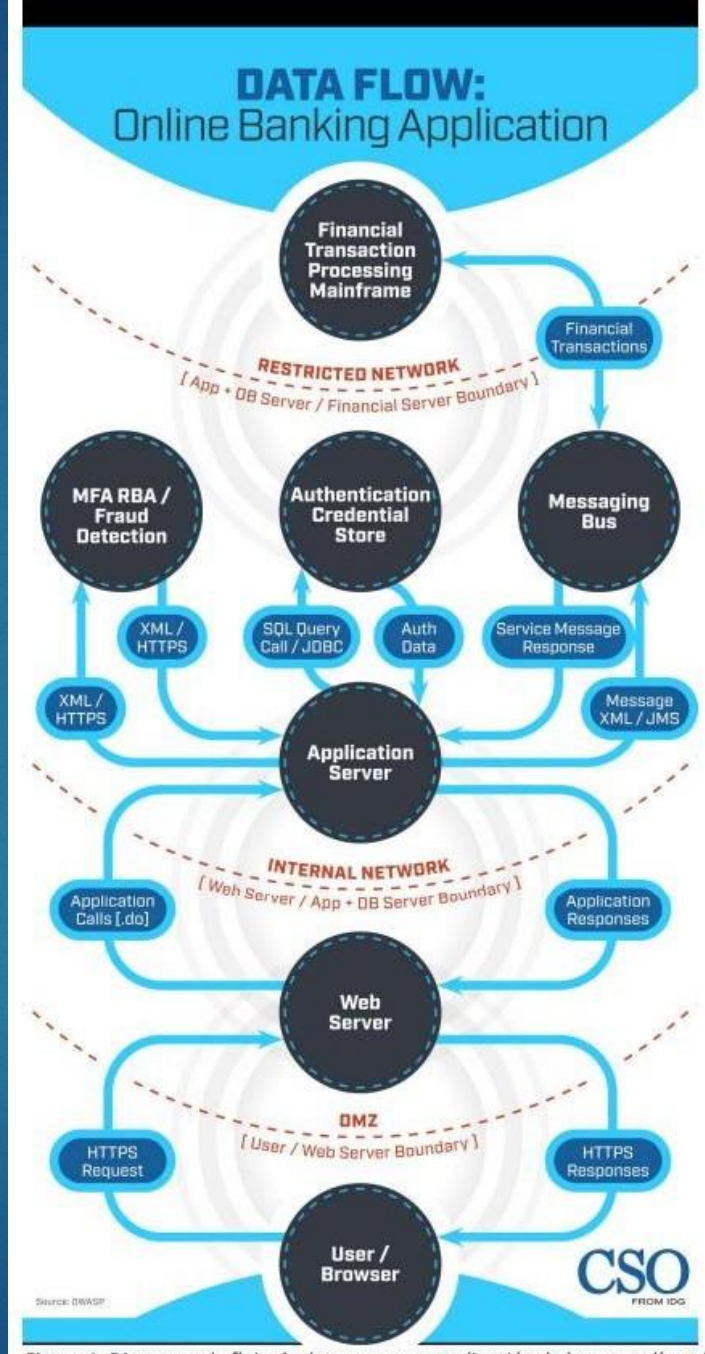
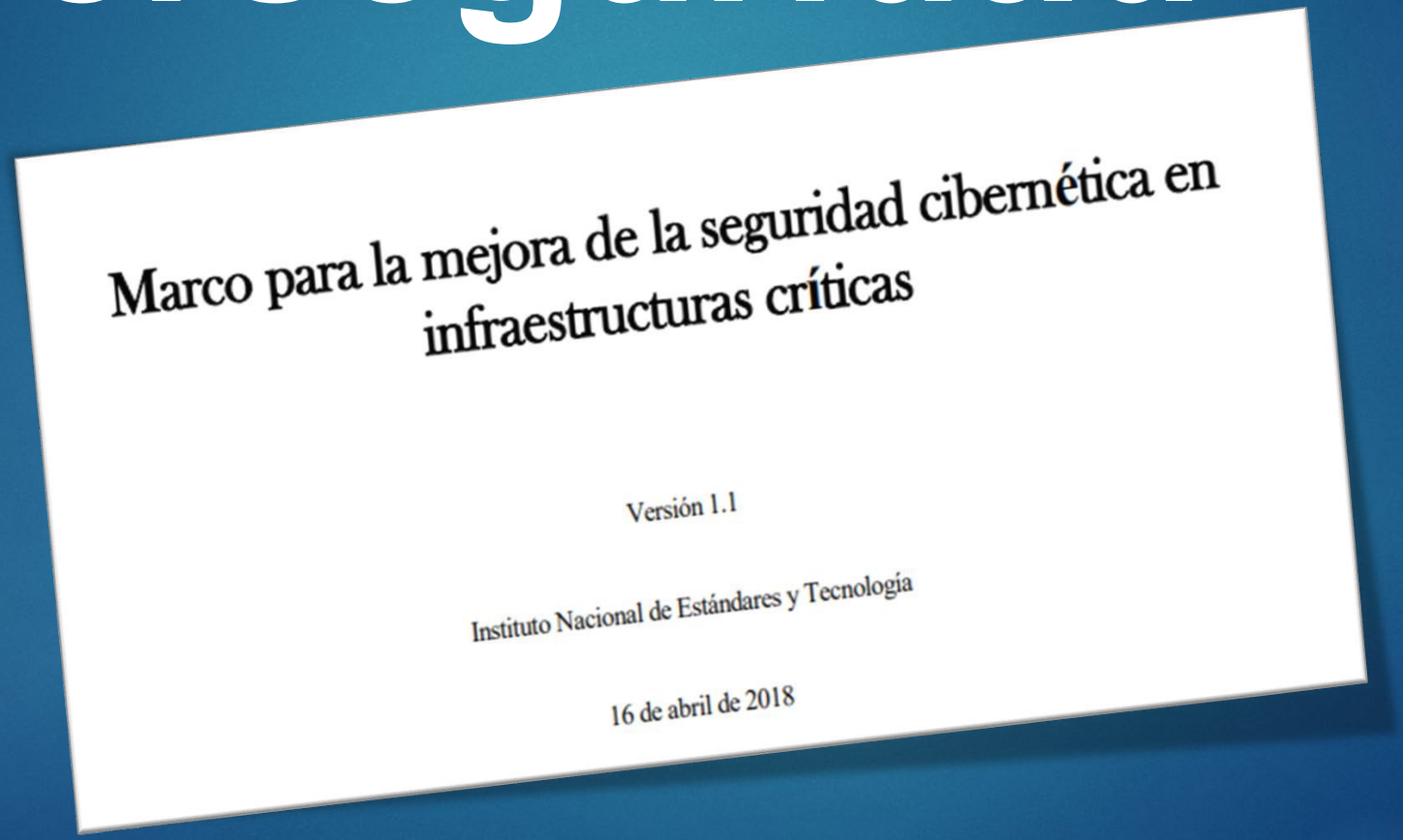


Figura 1. Diagrama de flujo de datos para una aplicación de banca en línea (de Wei Zhang y Marco Morana, distribuida bajo la licencia OWASP)

Marco de referencia de ciberseguridad


Marco para la mejora de la seguridad cibernética en infraestructuras críticas

Versión 1.1

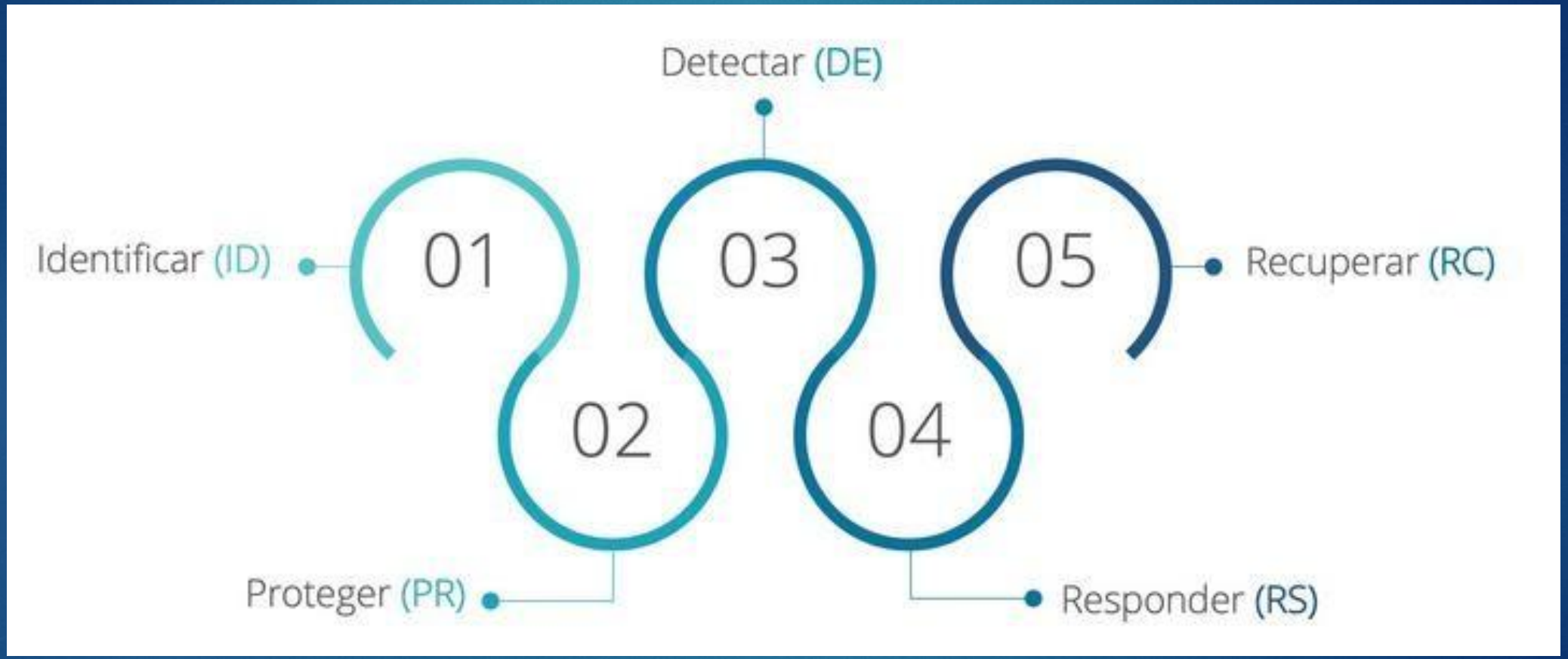
Instituto Nacional de Estándares y Tecnología

16 de abril de 2018

NIST Framework



https://www.argentina.gob.ar/jefatura/innovacion-publica/ssetic/onti/decalogo-tecnologico



https://www.esan.edu.pe/conexion/actualidad/2019/04/30/que-es-el-cybersecurity-framework-de-nist-de-los-estados-unidos/

FUNCIÓN IDENTIFICADOR ÚNICO	FUNCIONES	CATEGORÍA IDENTIFICADOR ÚNICO	CATEGORIAS
ID	IDENTIFICAR	ID.AM	Gestión de activos
		ID.BE	Ambiente de negocios
		ID.GV	Gobernanza
		ID.RA	Evaluación de riesgos
		ID.RM	Estrategia de gestión de riesgos
		ID.SC	Gestión del riesgo de la cadena de suministro
PR	PROTEGER	PR.AC	Gestión de identidad, autenticación y control de acceso
		PR.AT	Conciencia y capacitación
		PR.DS	Seguridad de datos
		PR.IP	Procesos y procedimientos de protección de la información
		PR.MA	Mantenimiento
		PR.PT	Tecnología de protección
DE	DETECTAR	DE.AE	Anomalías y Eventos
		DE.CM	Monitoreo continuo de seguridad
		DE.DP	Procesos de Detección
RS	RESPONDER	RS.RP	Planificación de respuesta
		RS.CO	Comunicaciones
		RS.AN	Análisis
		RS.MI	Mitigación
		RS.IM	Mejoras
		RS.RP	Planificación de respuesta
RC	RECUPERAR	RC.RP	Planificación de la recuperación
		RC.IM	Mejoras
		RC.CO	Comunicaciones

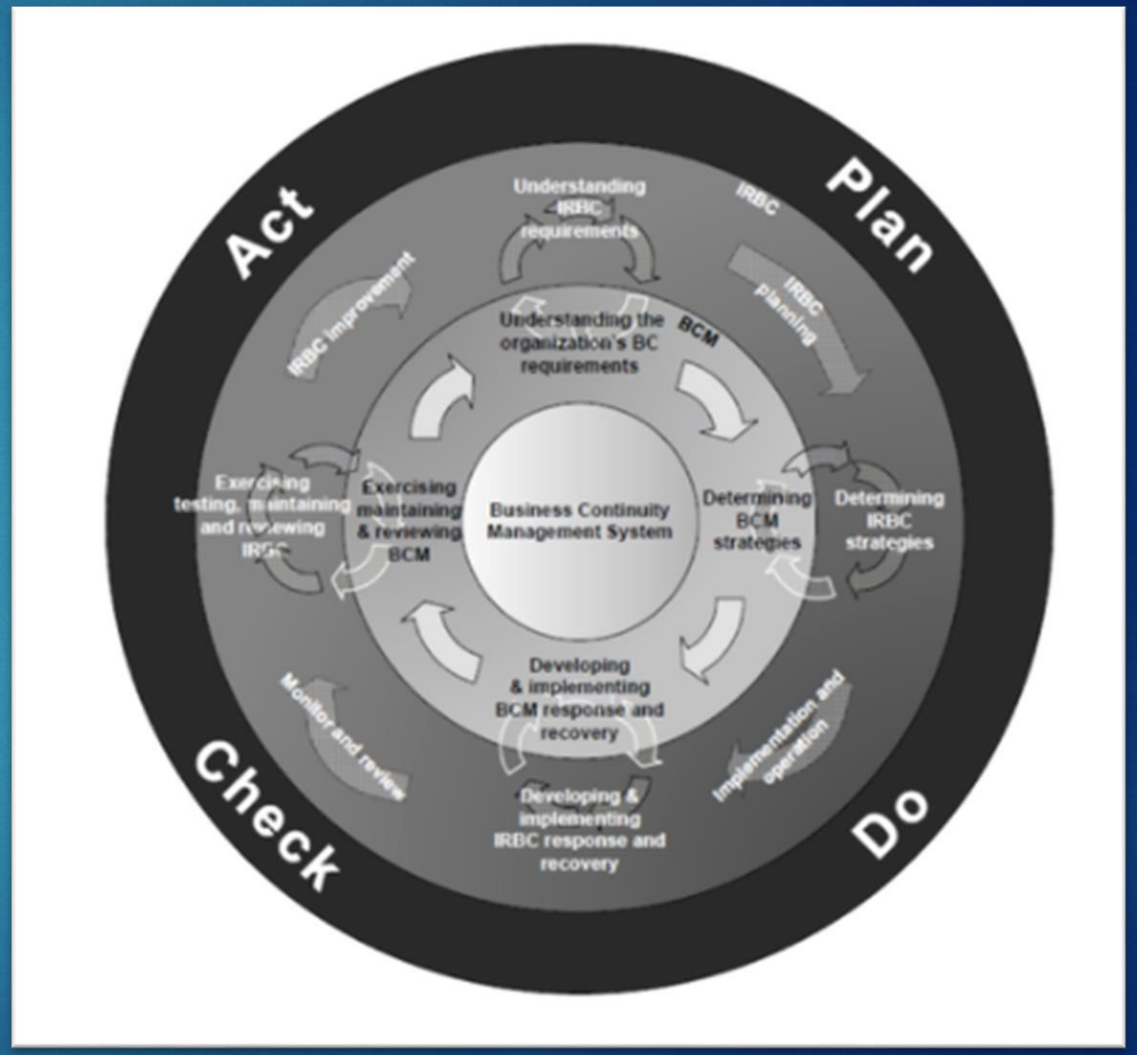
Plan de **continuidad del negocio**



Planificación de recuperacion (contingencias)

Proceso iterativo

- Promueve la resiliencia (soportar y recuperarse ante desastres).
  - Facilita la identificación de componentes críticos que componen el entorno de las TICs.
  - Justifica recursos.
  - Provee prácticas de monitoreo



https://www.iso.org/obp/ui/#iso:std:iso-iec:27031:ed-1:v1:en

Marco y normas de trabajo

ISO International Organization for Standardization

ISO/IEC 27031

STANDARD

Algunos principios fundamentales de diseño de la seguridad informática

- **Mínimo privilegio:** Los permisos otorgados a un sujeto deben estar basados en la necesidad de saber.
- **Valores por omisión seguros (Fallo seguro):** A menos que se otorgue explícitamente a un sujeto un objeto, éste debe ser denegado.. Ser Restrictivos y no permisivos.
- **Economía de mecanismos:** Los mecanismos de seguridad deben ser lo más simples posibles. Simplicidad
- **Mediación completa:** Todos los accesos a objetos deben poder auditarse.
- **Participación Universal**
- **Defensa en Profundidad**
- **Punto mas Débil**
- **Cuello de Botella**
- **Diversidad de Defensa**

Ransomware



El ransomware es malware usado por cibercriminales para secuestrar un dispositivo o la información almacenada en estos.

Dependiendo del tipo de ransomware:

– Encripta archivos importantes y pide el pago de un rescate a cambio de la clave de desencripción utilizada. Amenaza con borrar la clave luego de una fecha límite.

–Se hace pasar por la policía y extorsiona al usuario diciendo que se encontró pornografía y software pirata.

– Altera el arranque de la PC evitando que pueda encender.



Maze



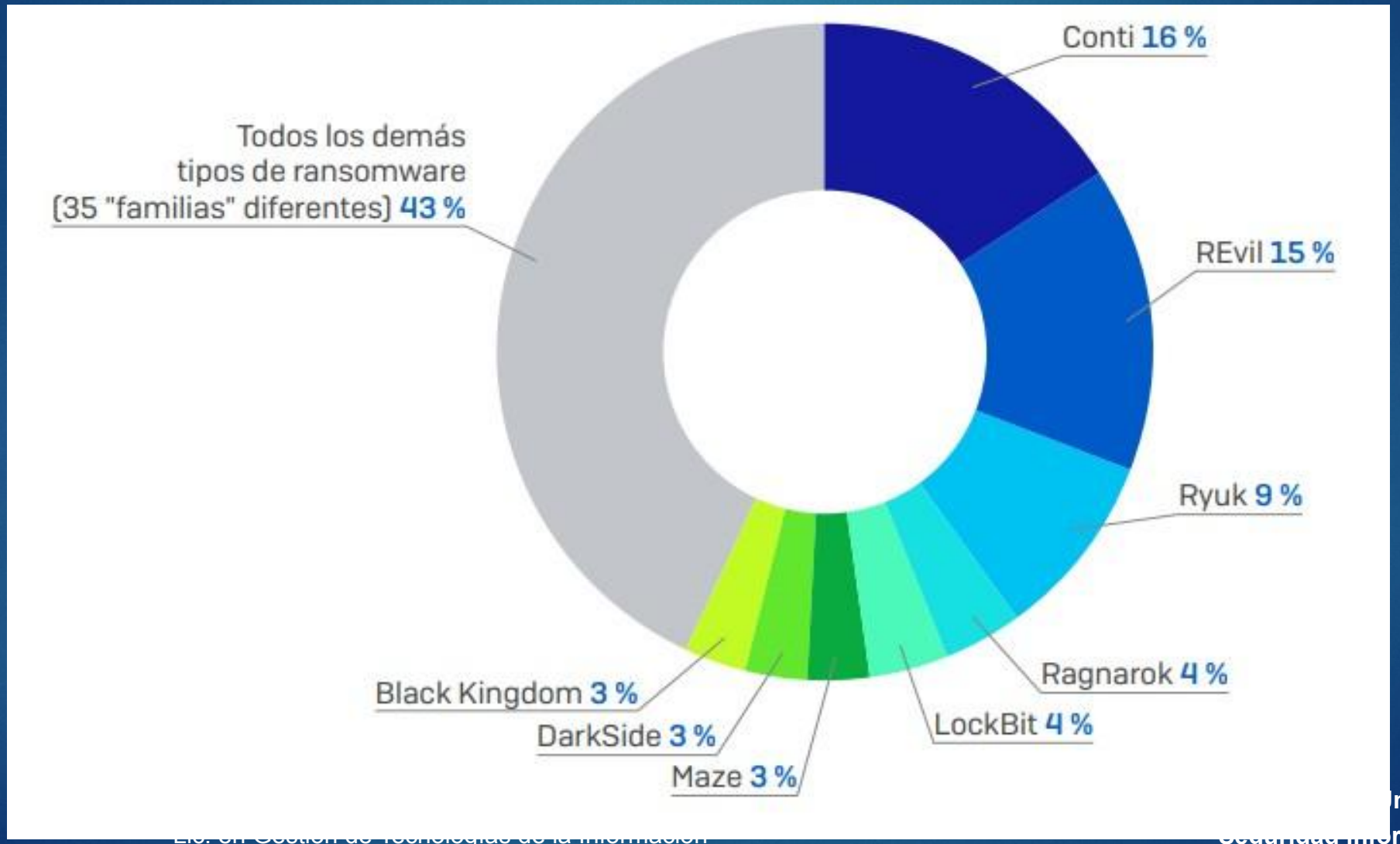
WannaCry (Quieres llorar)

Ransomware - Impacto Financiero



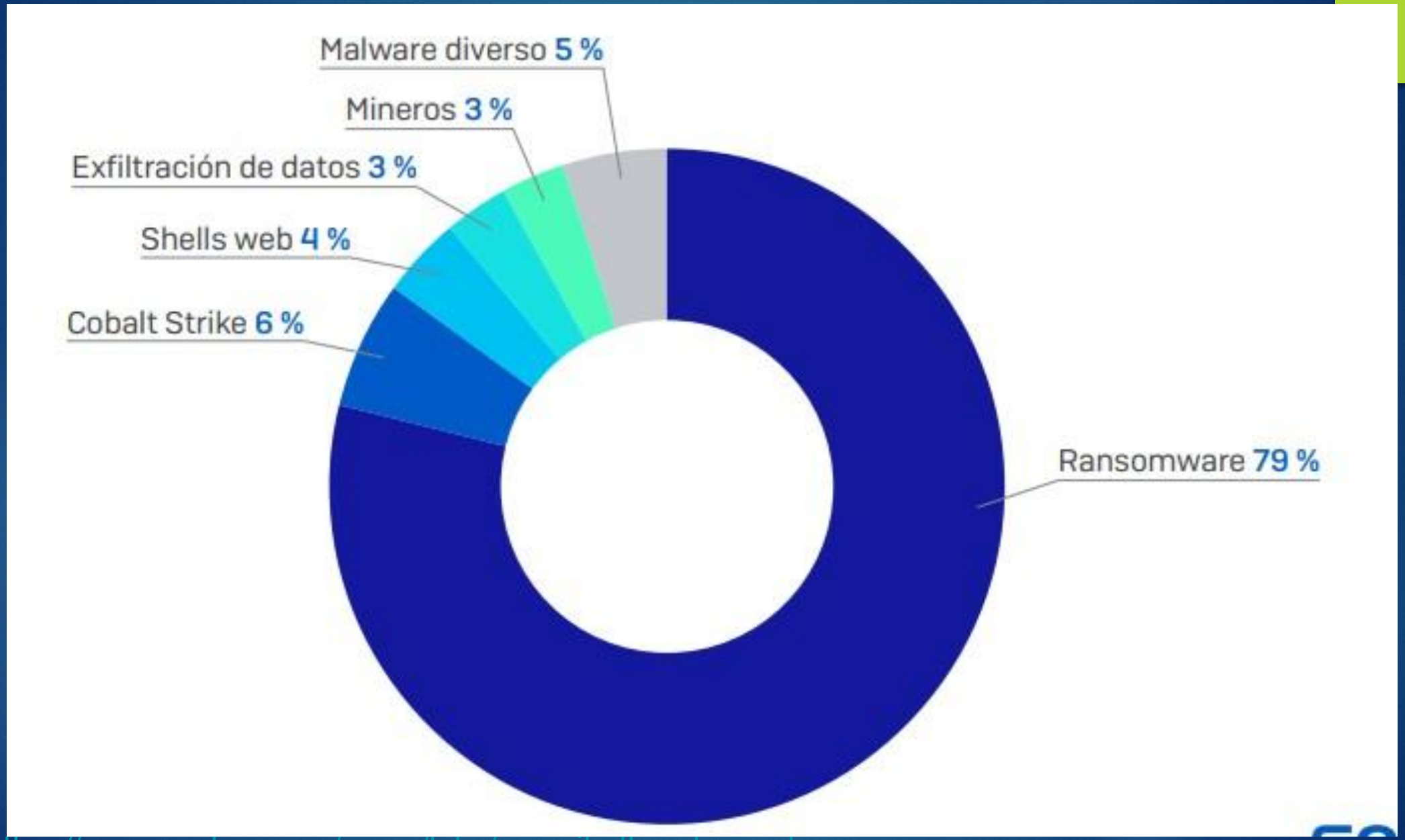
Figure 4. Longitudinal payment trend per family.

Ransomware - Actividad de versiones en la actualidad





- https://www.sophos.com/es-es/labs/security-threat-report.aspx



- https://www.sophos.com/es-es/labs/security-threat-report.aspx

- Video PESS, caso covid.

- Escáner de software
  https://scan.nextcloud.com

Noticias:
https://www.bbc.com/mundo/noticias-internacional-57033536
https://unaaldia.hispasec.com
https://www.welivesecurity.com/la-es/
https://www.segu-info.com.ar

Zero day

Un ataque de día cero es un ataque contra una aplicación o sistema con vulnerabilidades que son desconocidas para los usuarios y para el fabricante del producto.

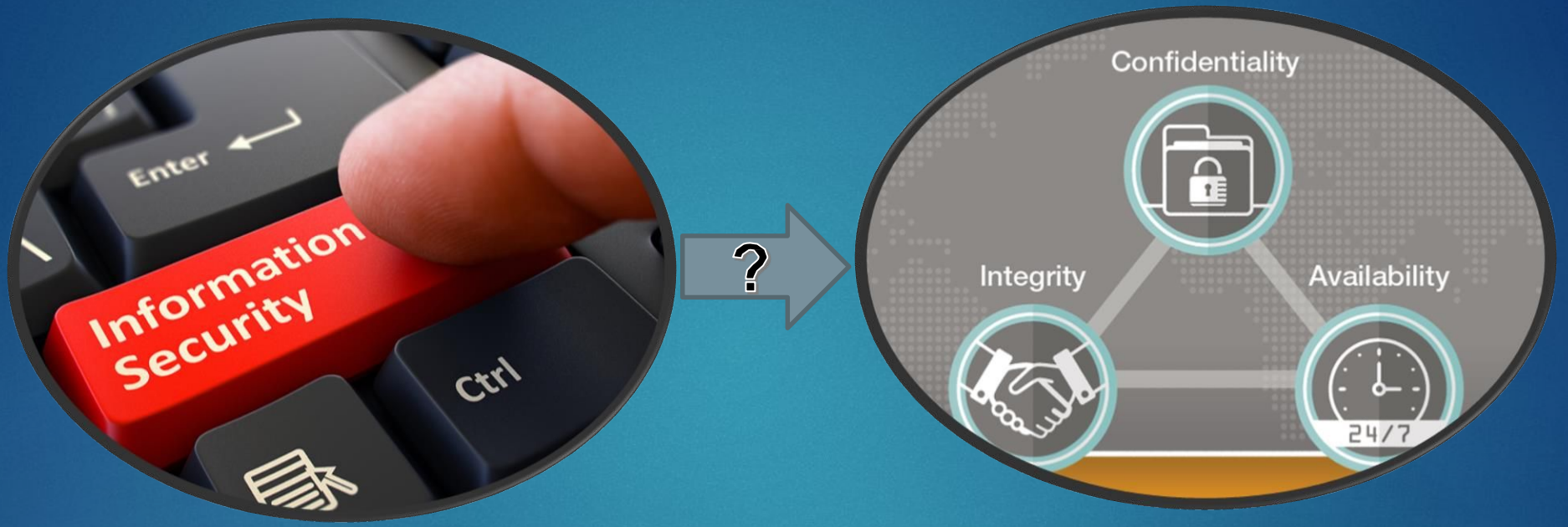
Microsoft, situación.



Cuando hablamos de seguridad, el eslabón más débil siempre es el empleado/usuario

¿Están de acuerdo con esta afirmación?
¿Por qué?
¿Quién es el responsable de esto?

Desafíos de la seguridad informática



La seguridad no es un producto , es un proceso continuo